Université Mohammed V de Rabat
Ecole Supérieure de Technologie de Salé

جامعة محمد الخامس بالرباط
المدرسة العليا للتكنولوجيا بسلا

Rapport de Projet de Fin d'Études (PFE)

Filière : Génie Informatique

Sujet :

Conception et Mise en Œuvre d'une Plateforme de Sécurité Réseau Basée sur OPNsense

Réalisé par :

Othman Benyahya

Lhachimi Mohamed Yassine

Encadré par :

Pr. Ali Lasfar

Pr. Younes Lourtassi

Soutenu le 10/04/2026 devant le Jury composé de :

M. Lefdaoui	Professeur, Ecole supérieure de Technologie.	***Jury***
M. Lasfar	Professeur, Ecole supérieure de Technologie.	***Jury***
M. Louartassi	Professeur, Ecole supérieure de Technologie.	***Jury***

Année Universitaire : 2025/2026

Dédicace

Il nous est particulièrement agréable d'ouvrir ce rapport par des mots de gratitude et de reconnaissance envers toutes les personnes qui, de près ou de loin, ont contribué à la réalisation de ce projet. Ce travail représente l'aboutissement d'un effort collectif, d'un soutien constant et d'un accompagnement précieux auxquels nous exprimons notre profonde gratitude.

Nous tenons tout d'abord à adresser nos sincères remerciements à nos familles, pour leur soutien moral inconditionnel, leurs encouragements permanents et les conditions idéales qu'elles nous ont offertes afin de mener à bien ce travail. Leur présence et leurs prières ont toujours été pour nous une source de motivation et de force.

Nous exprimons également notre profonde reconnaissance à notre encadrant Pr. Ali Lasfer, pour ses conseils, ses orientations, sa disponibilité et l'intérêt qu'il a porté à notre projet. Son accompagnement a joué un rôle essentiel dans l'avancement et la réussite de ce travail.

Nos remerciements s'adressent aussi à nos amis, qui nous ont soutenus par leurs avis, leurs remarques et leurs échanges constructifs tout au long de la réalisation de ce projet. Leur aide et leur présence ont été d'un grand apport.

À toutes celles et ceux qui, par leur soutien, leurs encouragements ou leurs conseils, ont contribué à la réussite de ce travail, nous adressons nos remerciements les plus sincères.

Othman benyahya & Lhachimi Mohamed Yassine

Résumé

À l'ère de la transformation numérique, la sécurisation des systèmes d'information est devenue un enjeu stratégique majeur pour les entreprises. Face à l'évolution constante et à la sophistication croissante des cybermenaces, les architectures réseaux traditionnelles, fondées sur une simple protection périmétrique, montrent leurs limites. Ce projet de fin d'études s'inscrit dans cette dynamique et propose la conception, l'implémentation et la validation d'une architecture réseau multi-sites hautement sécurisée, résiliente et évolutive. L'approche adoptée s'appuie sur les paradigmes modernes de la "Défense en Profondeur" (Defense in Depth) et du modèle "Confiance Zéro" (Zero Trust), garantissant qu'aucun flux, qu'il soit d'origine interne ou externe, n'est implicitement autorisé.

La solution technique, orchestrée autour de la plateforme pare-feu open-source OPNsense, repose sur une micro-segmentation stricte des environnements (LAN, DMZ, SRV, MGMT) régie par le principe de blocage par défaut (Deny by Default). Pour assurer la continuité d'activité, une infrastructure de routage avancée a été déployée, intégrant la répartition de charge (Load Balancing) et la tolérance aux pannes (Failover) sur des liaisons Multi-WAN. Par ailleurs, la confidentialité et l'intégrité des communications inter-sites sont assurées par un tunnel cryptographique OpenVPN, adossé à une infrastructure à clés publiques (PKI).

Au-delà du routage et du chiffrement, l'architecture intègre des couches d'inspection de niveau supérieur pour neutraliser proactivement les menaces. Un proxy web (Squid) assure le contrôle et le filtrage applicatif, tandis qu'un système de détection et de prévention d'intrusion (Suricata IDS/IPS) analyse le trafic en temps réel pour bloquer les comportements malveillants. L'ensemble de cette infrastructure a été rigoureusement validé à travers une série de tests pratiques (simulations de pannes matérielles, tentatives d'intrusion via Nmap, vérification des politiques d'accès), prouvant ainsi sa fiabilité, sa robustesse et sa pleine adéquation avec les exigences de sécurité d'une organisation moderne.

Mots-clés : Sécurité Réseau, Zero Trust, Défense en Profondeur, Micro-segmentation, OPNsense, VPN Site-à-Site, Suricata IDS/IPS, Haute Disponibilité.

Abstract

In the era of digital transformation, securing information systems has become a major strategic challenge for enterprises. Confronted with the constant evolution and increasing sophistication of cyber threats, traditional network architectures relying solely on perimeter protection are demonstrating their limitations. This final year project addresses this challenge by proposing the design, implementation, and validation of a highly secure, resilient, and scalable multi-site network architecture. The methodology relies on the modern paradigms of "Defense in Depth" and the "Zero Trust" model, ensuring that no network flow, whether internal or external, is implicitly trusted or authorized.

The technical solution, orchestrated around the open-source OPNsense firewall platform, is based on a strict micro-segmentation of environments (LAN, DMZ, SRV, MGMT) governed by the "Deny by Default" principle. To ensure business continuity, an advanced routing infrastructure was deployed, integrating Load Balancing and Failover mechanisms across Multi-WAN links. Furthermore, the confidentiality and integrity of inter-site communications are guaranteed by a cryptographic OpenVPN tunnel backed by a Public Key Infrastructure (PKI).

Beyond routing and encryption, the architecture integrates upper-layer inspection mechanisms to proactively neutralize threats. A web proxy (Squid) provides application-level filtering and access control, while an Intrusion Detection and Prevention System (Suricata IDS/IPS) analyzes real-time traffic to actively block malicious behaviors. The entire infrastructure was rigorously validated through a comprehensive series of practical tests, including hardware failure simulations, Nmap intrusion attempts, and strict access policy verifications. These results prove the system's reliability, robustness, and full compliance with the stringent security requirements of a modern organization.

Keywords: Network Security, Zero Trust, Defense in Depth, Micro-segmentation, OPNsense, Site-to-Site VPN, Suricata IDS/IPS, High Availability.

Table des matières

00. INTRODUCTION GÉNÉRALE P.12

01. CHAPITRE I :PRÉSENTATION DU PROJET ET ÉTUDE DE L'EXISTANT P.13

1. Introduction : p.14
2. Cadre du projet : p.14
3. Étude de l'existant : p.14
4. Problématique : p.15
5. Objectifs du projet : p.16
   - 5.1. Objectif général : p.16
   - 5.2. Objectif spécifiques : p.16
6. Solution proposée : p.17
7. Conclusion : p.18

02. CHAPITRE 2 : PLANIFICATION ET CONCEPTION DU PROJET P.19

1. Introduction : p.20
2. Méthodologie de travail : p.20
3. Planification temporelle : p.21
4. Analyse fonctionnelle : p.23
5. Conception de l'Architecture Globale : p.24
   - 5.1. Site Principal (Local) : p.24
   - 5.2. Site Distant (Hébergement de Services) : p.25
   - 5.3. Interconnexion VPN – Tunnel OpenVPN Site-à-Site : p.25
   - 5.4. Schéma topologique : p.25
6. Politique de sécurité p.27
7. Conclusion p.28

03. CHAPITRE 3 : ENVIRONNEMENT DE TRAVAIL ET TECHNOLOGIES P.29

1. Introduction : p.30
2. Environnement Matériel et Connectivité : p.30
   - 2.1. Les stations de travail (Hôtes) : p.30
   - 2.2. L'infrastructure de connectivité (Fournisseurs d'Accès Internet) : p.30
3. Environnement de Virtualisation : p.31
4. Systèmes d'Exploitation et Services Applicatifs : p.31
   - 4.1. Le Cœur du Réseau (OPNsense) p.31
   - 4.2 Les Systèmes Clients (Zone LAN) p.32
   - 4.3 Les Systèmes Serveurs (Zones DMZ & SRV) p.32

5. Technologies et Outils de Sécurité ---- p.33
5.1 OpenVPN (Tunneling et Chiffrement) ---- p.33
5.2. Suricata (Système de Détection et Prévention d'Intrusion - IDS/IPS) ---- p.33
5.3. Squid Proxy (Filtrage et Contrôle d'Accès Web) ---- p.34
5.4. Outils d'Audit, d'Administration et de Test ---- p.34
5.5. Outils de Modélisation et de Conception ---- p.35
6. Conclusion ---- p.35

04. CHAPITRE 4 : IMPLÉMENTATION ET RÉALISATION TECHNIQUE P.36

1. Introduction ---- p.37
2. Préparation et Configuration Initiale des Équipements ---- p.37
2.1. Déploiement des machines virtuelles (Hyperviseur) ---- p.37
2.2. Configuration matérielle des interfaces réseau (VirtualBox) ---- p.38
2.3. Attribution et adressage IP ---- p.39
2.4. Sécurisation des accès d'administration ---- p.40
3. Gestion du Routage et Haute Disponibilité (Multi-WAN) ---- p.41
3.1. Configuration du contrôle de bande passante (Traffic Shaping) ---- p.41
3.2. Implémentation de la Haute Disponibilité et de la Répartition de Charge ---- p.42
4. Déploiement du Tunnel VPN Site-à-Site (OpenVPN) ---- p.43
4.1. Infrastructure à Clés Publiques (PKI) et Certificats ---- p.43
4.2. Configuration des Instances OpenVPN (Serveur et Client) ---- p.44
5. Implémentation de la Politique de Sécurité "Zero Trust" ---- p.46
5.1. Sécurisation du Site Principal (Pare-feu Client) ---- p.46
5.2. Sécurisation du Site Distant (Pare-feu Serveur et Hébergement) ---- p.49
6. Contrôle et Filtrage du Trafic Web (Squid Proxy) ---- p.52
6.1. Implémentation du Proxy Transparent (Site Principal) ---- p.52
6.2. Implémentation du Proxy Explicite (Site Distant) ---- p.54
7. Déploiement du Système de Détection et Prévention d'Intrusion (IDS/IPS) p.56
7.1. Configuration du Moteur (Mode IPS) ---- p.56
7.2. Intégration des Signatures de Menaces (Emerging Threats Telemetry) ---- p.56
7.3. Création et Application de Règles Personnalisées (Custom Rules) ---- p.57
8. Conclusion ---- p.58

05.CHAPITRE 5 : TESTS ET VALIDATIONS P.59
1. Introduction p.60
2. Supervision Globale et Analyse du Trafic p.60
2.1. Le Tableau de Bord Centralisé (Dashboard) p.60
2.2. Analyse Visuelle et Granulaire du Trafic p.61
3. Validation du Routage et de la Haute Disponibilité (Multi-WAN) p.62
3.1. Test de la Qualité de Service (QoS) p.62
3.2. Test de Tolérance de Panne (Failover) p.62
3.3. Test de Répartition de Charge (Load Balancing) p.63
4.Validation du Tunnel VPN Site-à-Site p.64
4.1. État de l'instance Serveur (Site Distant) p.64
4.2. État de l'instance Client (Site Principal) p.64
5.Validation de la Politique de Sécurité "Zero Trust" p.65
5.1. Validation des privilèges d'administration inter-sites p.65
5.2. Validation de l'isolation du réseau utilisateurs (LAN) p.66
6.Validation du Filtrage Web (Squid Proxy) p.67
7.Validation de la Détection et Prévention d'Intrusion (Suricata) p.68
7.1. Simulation de l'attaque (Reconnaissance Nmap) p.68
7.2. Réponse et Blocage du système (Alertes IPS) p.69
8.Conclusion p.70
06. CONCLUSION GÉNÉRALE P.71
07. BIBLIOGRAPHIE ET WEBOGRAPHIE P.72

Table des figures

1. Figure 1 : Diagramme de Gantt p.22
2. Figure 2 : Schéma topologique réseau p.26
3. Figure 3 : Poste de travail (Laptop) p.30
4. Figure 4 : Connexion Fibre et 4G p.30
5. Figure 5: Logo Oracle VirtualBox p.31
6. Figure 6 : Logo OPNsense p.31
7. Figure 7 : Logo Lubuntu p.32
8. Figure 8 : Logo Kali Linux p.32
9. Figure 9 : Logo Apache Tomcat p.32
10. Figure 10 : Logo MariaDB p.32
11. Figure 11 : Logo OpenVPN p.33
12. Figure 12 : Logo Suricata p.33
13. Figure 13 : Logo Squid p.34
14. Figure 14 : Logo Nmap p.34
15. Figure 15 : Logo FileZilla p.34
16. Figure 16 : Logo Canva p.35
17. Figure 17 : Déploiement VM site principal p.37
18. Figure 18 : Déploiement VM site partenaire p.38
19. Figure 19 : Interfaces et adressage IP principal p.39
20. Figure 20 : Interfaces et adressage IP distant p.39
21. Figure 21 : Sécurisation interface Web GUI p.40
22. Figure 22 : Limitation bande passante (Pipes) p.41
23. Figure 23 : Règles trafic interface WAN p.42
24. Figure 24 : Groupe passerelles mode Failover p.43
25. Figure 25 : Groupe passerelles Load Balancing p.43
26. Figure 26 : Certificats VPN et CA serveur p.44
27. Figure 27 : Import certificats site principal p.44
28. Figure 28 : OpenVPN serveur site distant p.45

29. Figure 29 : OpenVPN client site principal p.45
30. Figure 30 : Blocage WAN par défaut p.46
31. Figure 31 : Règles LAN accès restreint p.47
32. Figure 32 : Règles MGMT administration réseau p.48
33. Figure 33 : Règles OpenVPN accès distant p.48
34. Figure 34 : Filtrage GeoIP et services WAN p.49
35. Figure 35 : Règles MGMT proxy et VPN p.50
36. Figure 36 : Règles DMZ micro-segmentation p.51
37. Figure 37 : Interface SRV sécurité par défaut p.51
38. Figure 38 : Contrôle accès OpenVPN RBAC p.52
39. Figure 39 : Activation proxy Squid p.53
40. Figure 40 : Redirection NAT vers proxy p.53
41. Figure 41 : Autorité certification inspection SSL p.54
42. Figure 42 : Base filtrage dynamique UT1 ..... p.54
43. Figure 43 : Configuration proxy client Windows p.55
44. Figure 44 : Activation Suricata mode IPS p.56
45. Figure 45 : Configuration token règles ET p.57
46. Figure 46 : Blocage attaques Nmap p.58
47. Figure 47 : Tableau bord système p.60
48. Figure 48 : Suivi flux réseau temps réel p.61
49. Figure 49 : Analyse connexions réseau (Top talkers) p.61
50. Figure 50 : Mesure débit client (5 Mbps) p.62
51. Figure 51 : Détection panne lien primaire p.63
52. Figure 52 : Statut passerelles actives p.63
53. Figure 53 : Validation mode Actif/Actif p.63
54. Figure 54 : Statut serveur OpenVPN distant p.64
55. Figure 55 : Connexion client VPN active p.64
56. Figure 56 : Validation accès réseau distant p.65
57. Figure 57 : Accès interfaces administration validé p.66
58. Figure 58 : Isolation réseau LAN validée p.67
59. Figure 59 : Blocage domaine proxy Squid p.68
60. Figure 60 : Scan Nmap agressif p.69
61. Figure 61 : Alertes Suricata attaque Nmap p.70

Liste des tableaux

1. Table 1 : Répartition des tâches au sein du binôme p.21
2. Tableau 2 : Matrice de filtrage inter-zones p.27

Table des abréviations

Abréviation	Signification
LAN	Local Area Network
WAN	Wide Area Network
DMZ	Demilitarized Zone
SRV	Serveur
MGMT	Management Network
VPN	Virtual Private Network
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
PKI	Public Key Infrastructure
UTM	Unified Threat Management
QoS	Quality of Service
SSL	Secure Sockets Layer
TLS	Transport Layer Security
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
DNS	Domain Name System
NTP	Network Time Protocol
GUI	Graphical User Interface
FAI	Fournisseur d’Accès Internet
SPOF	Single Point Of Failure
RBAC	Role-Based Access Control

Introduction Générale

À l'ère de la transformation numérique, les systèmes d'information constituent le cœur névralgique de toute organisation. Cependant, cette hyper-connectivité s'accompagne d'une complexité croissante et d'une exposition sans précédent aux cybermenaces. Face à des attaques de plus en plus sophistiquées, les architectures réseaux traditionnelles, fondées sur la simple protection périmétrique, montrent aujourd'hui leurs limites. Il est désormais impératif de repenser la sécurité en adoptant des paradigmes modernes, tels que la "Défense en Profondeur" (Defense in Depth) et la "Confiance Zéro" (Zero Trust), où chaque flux est inspecté, légitimé et segmenté.

C'est dans ce contexte exigeant que s'inscrit le présent Projet de Fin d'Études. L'objectif principal de ce travail est de concevoir, déployer et valider une architecture réseau multi-sites hautement sécurisée et résiliente. En s'appuyant sur la solution open-source OPNsense, le projet vise à démontrer comment une infrastructure d'entreprise peut intégrer des mécanismes avancés de haute disponibilité (Multi-WAN), de cryptographie (VPN Site-à-Site), de filtrage applicatif (Proxy) et de prévention d'intrusion (IDS/IPS), le tout orchestré par une politique de micro-segmentation stricte.

Afin d'exposer clairement la démarche d'ingénierie adoptée, ce rapport s'articule autour de cinq chapitres complémentaires :

Le premier chapitre dresse le contexte général du projet. Il y est présenté l'organisme d'accueil, l'analyse de l'existant, ainsi que les objectifs définis dans le cahier des charges.

Le deuxième chapitre est consacré à la conception de l'architecture. Il détaille l'approche théorique, la définition des zones de sécurité et l'élaboration de la matrice de flux globale régissant le modèle "Zero Trust".

Le troisième chapitre expose l'environnement de travail et justifie les choix technologiques retenus, tant au niveau de la virtualisation que des solutions de sécurité déployées.

Le quatrième chapitre constitue le cœur technique du projet. Il décrit avec précision l'implémentation et la configuration de chaque composant de l'infrastructure, du routage dynamique jusqu'aux règles de détection d'intrusion.

Enfin, le cinquième chapitre vient couronner cette démarche par une phase de tests et de validations. À travers l'analyse de journaux d'événements et la simulation d'attaques, ce chapitre apporte la preuve irréfutable de l'efficacité et de la robustesse des solutions mises en place.

Chapitre 1 :
Présentation du Projet et Étude de l'Existant

1. Introduction :

Ce premier chapitre a pour vocation de poser les fondations du projet. Il définit le cadre institutionnel dans lequel ce travail a été réalisé, analyse l'état actuel des infrastructures de sécurité classiques, et met en lumière la problématique justifiant le déploiement d'une architecture unifiée sous OPNsense. Enfin, il détaille les objectifs visés et la solution technique retenue.

2. Cadre du projet

Ce projet a été réalisé dans le cadre du Projet de Fin d'Études (PFE) au sein de l'École Supérieure de Technologie de Salé (EST Salé), dans la filière Génie Informatique. Il constitue une étape essentielle de la formation DUT, visant à valider les compétences acquises tout au long du cursus à travers la réalisation d'un projet pratique et structuré.

Dans un contexte où les systèmes d'information occupent une place centrale dans le fonctionnement des organisations, la sécurité des réseaux est devenue un enjeu majeur. L'augmentation des menaces informatiques, qu'elles soient internes ou externes, impose la mise en place de solutions capables de protéger les données, de garantir la disponibilité des services et de prévenir les attaques. Ce projet s'inscrit ainsi dans une démarche de compréhension et d'application des principes fondamentaux de la sécurité réseau.

Le travail a été mené dans un cadre expérimental et pédagogique, sous forme d'un travail en binôme, en s'appuyant sur un laboratoire virtualisé. Cet environnement permet de simuler une infrastructure réseau proche de celles rencontrées en entreprise, tout en offrant la possibilité de tester différentes configurations et scénarios de sécurité dans des conditions contrôlées.

Le périmètre du projet couvre la conception et la mise en œuvre d'une architecture réseau sécurisée, intégrant la segmentation des réseaux, le contrôle et le filtrage du trafic, la détection et la prévention des intrusions, ainsi que l'interconnexion sécurisée de réseaux distants. L'objectif est de mettre en pratique les connaissances acquises en informatique générale, en réseaux et en cybersécurité, tout en développant des compétences techniques et méthodologiques.

Dans ce cadre, la solution OPNsense a été retenue comme plateforme principale. Ce choix s'explique par son caractère open-source, sa richesse fonctionnelle et sa capacité à intégrer plusieurs mécanismes de sécurité tels que le pare-feu, le proxy, l'IDS/IPS, le VPN et la gestion multi-WAN. OPNsense constitue ainsi une solution adaptée aussi bien aux besoins pédagogiques qu'aux exigences des environnements professionnels.

3. Étude de l'existant :

L'étude de l'existant consiste à analyser les architectures réseau classiques couramment déployées dans les petites et moyennes infrastructures, afin d'identifier leurs faiblesses et leurs limites techniques. Historiquement, la sécurité périmétrique reposait sur des modèles simples, qui se révèlent aujourd'hui insuffisants face à l'évolution des menaces informatiques.

L'analyse d'une infrastructure réseau de base, telle que celle fournie par défaut par les routeurs des Fournisseurs d'Accès Internet ou par des pare-feux de génération ancienne, met en évidence plusieurs lacunes majeures.

Tout d'abord, ces architectures reposent généralement sur une topologie réseau plate, caractérisée par l'absence de segmentation. Les postes utilisateurs, les serveurs et les équipements d'administration partagent souvent le même réseau local (LAN). Cette absence d'isolation facilite la propagation des menaces, puisqu'une compromission d'un seul poste peut affecter l'ensemble du système d'information.

Ensuite, le filtrage du trafic est limité aux couches réseau et transport. Les pare-feux traditionnels se basent principalement sur les adresses IP et les ports (couches 3 et 4 du modèle OSI), sans analyser le contenu applicatif. Ils sont ainsi incapables de détecter des charges malveillantes dissimulées dans des flux chiffrés, notamment au sein des connexions HTTPS.

Par ailleurs, ces infrastructures présentent souvent une absence de redondance et de tolérance aux pannes. L'utilisation d'un lien WAN unique constitue un point de défaillance critique (Single Point of Failure – SPOF). En cas de panne, l'accès aux services est totalement interrompu, ce qui impacte directement la disponibilité du réseau.

Un autre point faible réside dans le manque de mécanismes de détection proactive. Les architectures classiques ne disposent généralement pas de systèmes capables de détecter en temps réel les comportements anormaux, tels que les balayages de ports ou les tentatives d'intrusion, en raison de l'absence de solutions IDS/IPS.

Enfin, l'interconnexion distante et l'accès pour les utilisateurs nomades sont souvent mal sécurisés ou complexes à mettre en œuvre. Ces fonctionnalités nécessitent fréquemment des équipements propriétaires coûteux, limitant la flexibilité et le contrôle sur les mécanismes de chiffrement et d'authentification.

Ce constat met en évidence les limites des approches de sécurité traditionnelles et souligne la nécessité d'adopter une architecture réseau moderne

4. Problématique :

À la lumière de l'étude de l'existant, il apparaît clairement que les architectures de sécurité périmétriques traditionnelles ne sont plus suffisantes pour faire face à des cybermenaces en constante évolution. La multiplication des attaques sophistiquées ciblant directement la couche applicative (couche 7), ainsi que l'utilisation généralisée du chiffrement par les acteurs malveillants pour dissimuler leurs activités, rendent les pare-feux classiques limités aux couches 3 et 4 largement inefficaces.

Par ailleurs, les exigences actuelles en matière de connectivité imposent aux infrastructures informatiques d'être de plus en plus ouvertes et accessibles. L'exposition nécessaire de certains services internes, tels qu'un serveur web, combinée au besoin croissant d'interconnecter des sites distants ou de permettre le télétravail sécurisé, entraîne une augmentation significative de la surface

d'attaque. En l'absence d'une segmentation stricte, d'une inspection approfondie du trafic et d'un contrôle rigoureux des flux, la moindre faille peut conduire à la compromission de l'ensemble du système d'information.
De plus, la continuité de service constitue aujourd'hui un enjeu critique pour les organisations. Une infrastructure de sécurité, même performante, peut devenir un point de défaillance majeur (Single Point of Failure – SPOF) si elle ne prévoit pas de mécanismes de redondance et de tolérance aux pannes au niveau des liaisons Internet.
Dans ce contexte, la problématique centrale qui motive ce projet de fin d'études peut être formulée comme suit :
Comment concevoir, simuler et déployer une architecture réseau de nouvelle génération, à la fois unifiée, résiliente et évolutive, capable d'assurer une défense en profondeur — incluant la segmentation du réseau, l'inspection applicative et la détection des intrusions — tout en garantissant une haute disponibilité et une interconnexion distante sécurisée, en s'appuyant sur des solutions open-source ?
Cette problématique met en évidence plusieurs défis techniques et conceptuels, qui seront abordés à travers la définition d'objectifs précis et la mise en œuvre d'une solution globale de sécurité réseau.

5. Objectifs du projet :

Afin de répondre de manière cohérente et complète à la problématique identifiée, ce projet s'articule autour d'un ensemble d'objectifs clairement définis. Ces objectifs visent à couvrir les principaux piliers de la sécurité de l'information, à savoir la confidentialité, l'intégrité et la disponibilité. Ils se déclinent en un objectif général, complété par plusieurs objectifs spécifiques.

5.1. Objectif général :

L'objectif principal de ce projet est de concevoir, déployer et valider une plateforme unifiée de sécurité réseau de nouvelle génération (Next-Generation Firewall), entièrement basée sur la solution open-source OPNsense. Cette plateforme a pour vocation de mettre en place une architecture de défense en profondeur, capable de segmenter finement les flux réseau, d'assurer une inspection applicative avancée, de détecter et prévenir les menaces, tout en garantissant une haute disponibilité des services.

5.2. Objectif spécifique :

Pour concrétiser cet objectif global, plusieurs objectifs techniques et opérationnels ont été définis :

- **Segmenter et isoler l'infrastructure réseau :** Définir et configurer des zones de sécurité distinctes et étanches, notamment le réseau LAN pour les utilisateurs, la DMZ pour les services exposés et le réseau SRV pour les bases de données critiques, afin de réduire la surface d'attaque

et de limiter les mouvements latéraux en cas d'intrusion.

- **Garantir la continuité de service (Disponibilité) :** Mettre en œuvre une architecture Multi-WAN intégrant des mécanismes d'équilibrage de charge (Load Balancing) et de tolérance aux pannes (Failover), afin d'assurer un accès Internet fiable et ininterrompu.
- **Contrôler et filtrer le trafic réseau (Confidentialité et conformité) :** Déployer un proxy transparent associé à une inspection SSL (HTTPS) et à une redirection DNS stricte, dans le but de maîtriser les accès au Web et d'empêcher les tentatives de contournement des politiques de sécurité.
- **Détecter et bloquer les attaques (Intégrité) :** Intégrer et configurer le moteur Suricata en tant que système de détection et de prévention des intrusions (IDS/IPS), capable d'analyser le trafic en temps réel et de bloquer activement les comportements malveillants.
- **Sécuriser les interconnexions distantes :** Mettre en place une infrastructure à clés publiques (PKI) interne pour assurer une authentification forte, et déployer des tunnels chiffrés via OpenVPN, répondant aux besoins d'accès distant des utilisateurs (VPN Nomade) ainsi qu'à l'interconnexion sécurisée de réseaux distincts (VPN Site-à-Site).
- **Valider l'architecture par la simulation et les tests :** Évaluer la robustesse de la solution déployée à travers des tests de connectivité, des scénarios de basculement et des simulations d'attaques (Red Teaming), suivis d'une analyse des journaux et des mécanismes de défense (Blue Teaming).

6. Solution proposée :

Afin de répondre efficacement à la problématique identifiée et d'atteindre les objectifs de sécurité définis, le choix technique s'est porté sur la mise en place d'une architecture unifiée de sécurité réseau basée sur la solution OPNsense.

OPNsense est une plateforme open-source de pare-feu et de routage, reconnue pour sa robustesse, sa flexibilité et sa richesse fonctionnelle. Basée sur le système d'exploitation FreeBSD et issue de l'évolution des solutions de pare-feu modernes, elle s'impose aujourd'hui comme une solution performante de gestion unifiée des menaces (UTM – Unified Threat Management), répondant aux exigences actuelles en matière de sécurité réseau.

Contrairement aux équipements matériels propriétaires, souvent coûteux et peu transparents, OPNsense offre une visibilité complète sur les mécanismes de traitement du trafic et une grande liberté de configuration. Elle permet de centraliser l'ensemble des fonctions de sécurité au sein d'une seule plateforme, facilitant ainsi l'administration et le contrôle du réseau.

La solution proposée s'appuie sur les principales fonctionnalités offertes par OPNsense, notamment :

- **Routage avancé et gestion Multi-WAN :** La plateforme permet de gérer plusieurs connexions Internet simultanément, assurant la haute disponibilité grâce au mécanisme de failover, ainsi que l'optimisation de la bande passante via l'équilibrage de charge (load balancing).

- **Filtrage applicatif et proxy transparent :** L'intégration du service Squid permet un contrôle précis du trafic web, renforcé par des capacités d'inspection SSL, offrant ainsi une meilleure visibilité sur les flux chiffrés.
- **Détection et prévention des intrusions (IDS/IPS) :** L'intégration native du moteur Suricata assure une analyse approfondie du trafic en temps réel, permettant d'identifier et de bloquer activement les tentatives d'attaque.
- **Réseaux privés virtuels (VPN) :** La prise en charge d'OpenVPN permet la mise en place d'une infrastructure à clés publiques (PKI) et la sécurisation des communications distantes, aussi bien pour l'accès des utilisateurs nomades que pour l'interconnexion sécurisée de réseaux distincts.

En regroupant l'ensemble de ces services au sein d'une interface d'administration web unique et sécurisée, OPNsense permet de construire une architecture de défense en profondeur, cohérente, évolutive et résiliente. Ce choix technologique répond pleinement aux exigences académiques et techniques de ce projet de fin d'études.

7. Conclusion :

Ce premier chapitre a permis de poser le cadre général et les fondements conceptuels du projet. L'analyse des architectures réseau traditionnelles a mis en évidence leurs limites et leurs vulnérabilités face aux menaces informatiques actuelles, soulignant ainsi la nécessité d'adopter une approche de sécurité plus globale et structurée, basée sur le principe de la défense en profondeur.

La formulation d'une problématique claire a conduit à la définition d'objectifs techniques précis, intégrant la segmentation du réseau, la haute disponibilité des services, le contrôle et le filtrage du trafic, ainsi que la sécurisation des interconnexions distantes. Dans ce contexte, le choix de la solution open-source OPNsense s'est imposé comme une réponse cohérente et adaptée, capable de centraliser l'ensemble des mécanismes de sécurité au sein d'une architecture unifiée.

Après avoir défini le contexte, les enjeux et la solution retenue, le chapitre suivant sera consacré à la planification du projet et à la conception de l'architecture globale, en présentant l'organisation du travail, la planification temporelle des tâches et la structure technique du réseau qui sera mise en œuvre.

Chapitre 2 :
Planification et Conception du Projet

1. Introduction :

Après avoir défini le contexte général du projet, analysé les limites des architectures existantes et présenté la solution retenue, ce chapitre est consacré à la planification et à la conception du projet. Il vise à décrire l'approche méthodologique adoptée pour organiser le travail, structurer les différentes phases du projet et assurer une mise en œuvre cohérente de la solution proposée.
Ce chapitre présente dans un premier temps la méthodologie de travail suivie, basée sur une collaboration en binôme et une répartition structurée des tâches. Il aborde ensuite la planification temporelle du projet à travers un diagramme de Gantt, avant de détailler la conception fonctionnelle et topologique de l'architecture réseau. Cette étape constitue un élément clé, permettant de traduire les objectifs définis en une architecture technique claire et maîtrisée, préalable indispensable à la phase d'implémentation.

2. Méthodologie de travail :

Dans le cadre de ce projet de fin d'études, une méthodologie de travail structurée a été adoptée afin d'assurer une progression cohérente et efficace des différentes phases du projet. Le travail a été réalisé en binôme, en combinant collaboration, répartition des responsabilités et validation continue des résultats obtenus.
La méthodologie suivie repose sur une approche progressive et itérative, allant de l'analyse des besoins à la conception, puis à l'implémentation et à la validation de la solution. Les tâches ont été réparties de manière complémentaire, tout en maintenant une coordination permanente entre les membres du binôme.

La répartition des responsabilités s'est articulée selon l'organisation suivante :

Membre du Binôme	Responsabilités et Tâches Principales
Othman Benyahya	• Conception et mise en place de l'architecture de sécurité réseau globale • Configuration avancée d'OPNsense • Implémentation du Multi-WAN, du Load Balancing et du Failover • Déploiement et configuration du proxy transparent avec inspection SSL • Mise en place et réglage du système IDS/IPS Suricata • Réalisation des scénarios de tests de sécurité et simulations d'attaques • Analyse des journaux et évaluation des mécanismes de défense
Lhachimi Mohamed Yassine	• Mise en place des réseaux internes dédiés aux services • Déploiement et configuration du serveur Web dans la zone DMZ • Déploiement et sécurisation du serveur de base de données dans le réseau SRV • Configuration des règles de pare-feu inter-zones (LAN, DMZ, SRV, WAN) • Participation aux tests de connectivité et de validation des services
Travail commun	• Analyse de l'existant et définition de la problématique • Conception de l'architecture globale et du schéma topologique • Mise en place de l'environnement de laboratoire virtualisé • Déploiement de l'infrastructure VPN (VPN Nomade et VPN Site-à-Site) • Élaboration de la documentation technique et rédaction du rapport • Validation finale de la solution et interprétation des résultats

Table 1 : Répartition des tâches au sein du binôme

3. Planification temporelle :

La maîtrise des délais et l'organisation séquentielle des tâches constituent des facteurs déterminants pour la réussite d'un projet de fin d'études. Afin de garantir une progression fluide et de respecter l'échéance finale fixée au mois d'avril, une planification rigoureuse a été établie dès le lancement des travaux.

Le projet a été découpé en plusieurs phases majeures, allant de l'étude théorique à la rédaction finale du rapport, en passant par les étapes critiques de configuration et de sécurisation. Cette feuille de route a été formalisée à l'aide d'un Diagramme de Gantt, permettant de visualiser l'ordonnancement des tâches et les dépendances entre elles.

Le calendrier de réalisation s'est articulé autour des phases suivantes :

- **Phase 1 :** Analyse et Étude (Novembre 2025) : Définition de la problématique, recherche documentaire sur les solutions UTM (Unified Threat Management) et étude comparative des fonctionnalités d'OPNsense.
- **Phase 2 :** Conception et Laboratoire (Décembre 2025) : Élaboration du schéma topologique, définition de la matrice de flux (politique de sécurité) et mise en place de l'environnement de virtualisation.

- **Phase 3 :** Implémentation de l'Infrastructure (Janvier - Février 2026) : Configuration des interfaces, mise en place du Multi-WAN (Failover/Load Balancing) et déploiement du Proxy transparent avec inspection SSL.
- **Phase 4 :** Services Avancés et Interconnexion (Mars 2026) : Déploiement de la DMZ, configuration du serveur Web et de la base de données, mise en place de l'IDS/IPS Suricata et établissement des tunnels VPN (Nomade et Site-à-Site).
- **Phase 5** : Validation et Rédaction (Avril 2026) : Réalisation des scénarios de tests (Red Teaming/Blue Teaming), analyse des résultats et finalisation du rapport de PFE.

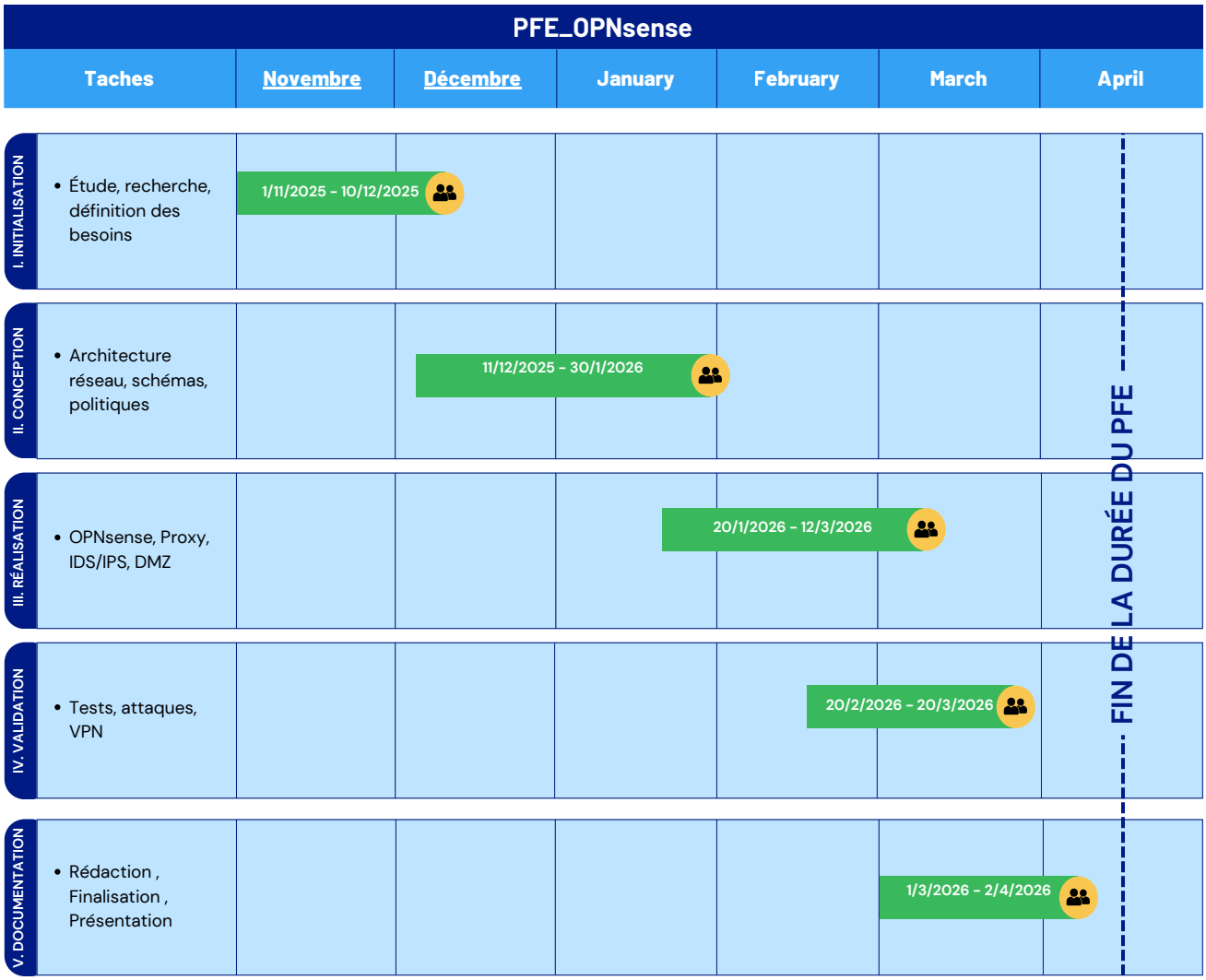


Figure 1: Diagramme de Gantt

4. Analyse fonctionnelle :

L'analyse fonctionnelle constitue une étape charnière dans la conception du projet. Elle a pour but de traduire les exigences de sécurité et les lacunes identifiées lors de l'étude de l'existant en spécifications techniques claires et mesurables. Pour répondre efficacement à la problématique centrale, l'architecture cible doit impérativement intégrer un ensemble de services critiques, chacun répondant à un besoin de sécurité spécifique.
Les fonctionnalités attendues du système global ont été définies comme suit :

A. Segmentation et cloisonnement des flux (Pare-feu) :

Le système doit permettre de diviser l'infrastructure en zones de confiance distinctes :

- un réseau LAN pour les utilisateurs,
- une DMZ pour les services exposés,
- un réseau SRV pour les bases de données.

Le filtrage inter-zones doit suivre le principe du moindre privilège, en n'autorisant que les flux explicitement nécessaires.

B. Haute disponibilité et ingénierie du trafic (Multi-WAN) :

Pour éviter tout point de défaillance unique lié à l'accès Internet, l'architecture doit gérer plusieurs liaisons WAN. Elle doit intégrer :

- un mécanisme d'équilibrage de charge (Load Balancing),
- un basculement automatique (Failover), afin d'assurer une disponibilité continue des services.

C. Contrôle d'accès et filtrage Web (Proxy & DNS) :

La solution doit inclure un proxy transparent (Squid) permettant de contrôler et journaliser la navigation Web. Compte tenu de la généralisation du trafic chiffré, le proxy doit intégrer une inspection SSL (HTTPS). Un DNS Forwarding strict doit également être mis en place pour empêcher tout contournement des politiques de filtrage.

D. Détection et prévention proactive (IDS/IPS) :

Le système doit intégrer un moteur d'analyse en temps réel, basé sur Suricata, capable de :

- détecter les comportements anormaux (mode IDS),
- bloquer activement les paquets malveillants (mode IPS).

Ce module complète le filtrage traditionnel en apportant une visibilité approfondie sur les attaques réseau.

E. nterconnexion sécurisée et cryptographie (PKI & VPN) :

L'infrastructure doit garantir la confidentialité et l'intégrité des communications distantes via :

1. une Autorité de Certification (PKI) interne pour la gestion des certificats,
2. des tunnels OpenVPN couvrant deux scénarios :
   - VPN Nomade pour les utilisateurs distants,
   - VPN Site-à-Site pour l'interconnexion de réseaux locaux distincts.

L'ensemble de ces spécifications constitue le cahier des charges fonctionnel du projet et servira de base à la conception détaillée de l'architecture réseau présentée dans la section suivante.

5. Conception de l'Architecture Globale :

La conception de l'architecture globale constitue l'aboutissement logique de l'analyse fonctionnelle. Elle permet de traduire les exigences de sécurité en une structure réseau claire, segmentée et conforme aux principes de défense en profondeur. L'objectif est de modéliser une architecture capable d'assurer la haute disponibilité, l'isolation des services critiques et l'interconnexion sécurisée entre plusieurs sites.
L'infrastructure retenue repose sur une architecture distribuée multi-sites, interconnectée via un tunnel VPN chiffré. Chaque site est protégé par une passerelle OPNsense, assurant à la fois le routage, le filtrage, l'analyse du trafic et la gestion des services avancés.

5.1. Site Principal (Local) :

Ce site représente l'environnement utilisateur et constitue le point d'accès principal vers Internet. Il est organisé en trois zones fonctionnelles :

• Zone LAN – 10.0.0.0/24 :
Elle regroupe les postes clients (ex. machines Lubuntu et Kali Linux).
Le trafic sortant est soumis à :

- un proxy transparent avec inspection SSL,
- un IDS/IPS Suricata,
- des règles de filtrage strictes.

• Zone Multi-WAN :
Elle assure la continuité de service grâce à deux liens Internet :

- ISP1 : 192.168.8.0/24 (lien principal)
- ISP2 : 10.20.209.0/24 (lien secondaire)

Ces liens fonctionnent en Load Balancing et Failover, garantissant une disponibilité maximale.

• **Zone MGMT – 192.168.56.0/24 :**
Réseau isolé de type Host-Only, exclusivement dédié à l'administration sécurisée du pare-feu.
Il permet d'éviter toute exposition de l'interface d'administration sur les réseaux utilisateurs.

5.2. Site Distant (Hébergement de Services) :

Ce site est dédié à l'exposition et à la protection des services applicatifs. Il adopte une segmentation renforcée afin d'isoler les composants critiques.

- **Zone DMZ – 192.168.228.0/24 :**
  Zone démilitarisée hébergeant le serveur Web (192.168.228.4).
  Elle est accessible depuis Internet, mais strictement isolée du réseau interne.
- **Zone SRV – 192.168.130.0/24 :**
  Zone hautement sécurisée contenant le serveur de base de données (192.168.130.4).
  Elle n'accepte que les requêtes provenant de la DMZ, conformément au principe du moindre privilège.
- **Zone MGMT Distante – 192.168.89.0/24 :**
  Réseau réservé à l'administration locale de la passerelle distante.

5.3. Interconnexion VPN – Tunnel OpenVPN Site-à-Site :

Pour relier les deux sites en un réseau logique unique, un tunnel OpenVPN Site-à-Site a été déployé. Il utilise le sous-réseau 10.0.8.0/24, avec :

- OPNsense Local : 10.0.8.1
- OPNsense Distant : 10.0.8.2

Ce tunnel assure :

- la confidentialité des échanges,
- l'intégrité des données,
- la communication transparente entre les zones internes des deux sites.

5.4. Schéma topologique :

Le schéma suivant illustre l'architecture globale décrite précédemment. Il synthétise le découpage logique des réseaux, la segmentation des zones de sécurité, ainsi que les mécanismes de haute disponibilité et d'interconnexion sécurisée mis en œuvre entre le site principal et le site distant. Cette représentation permet de visualiser de manière claire et cohérente l'organisation générale de l'infrastructure.

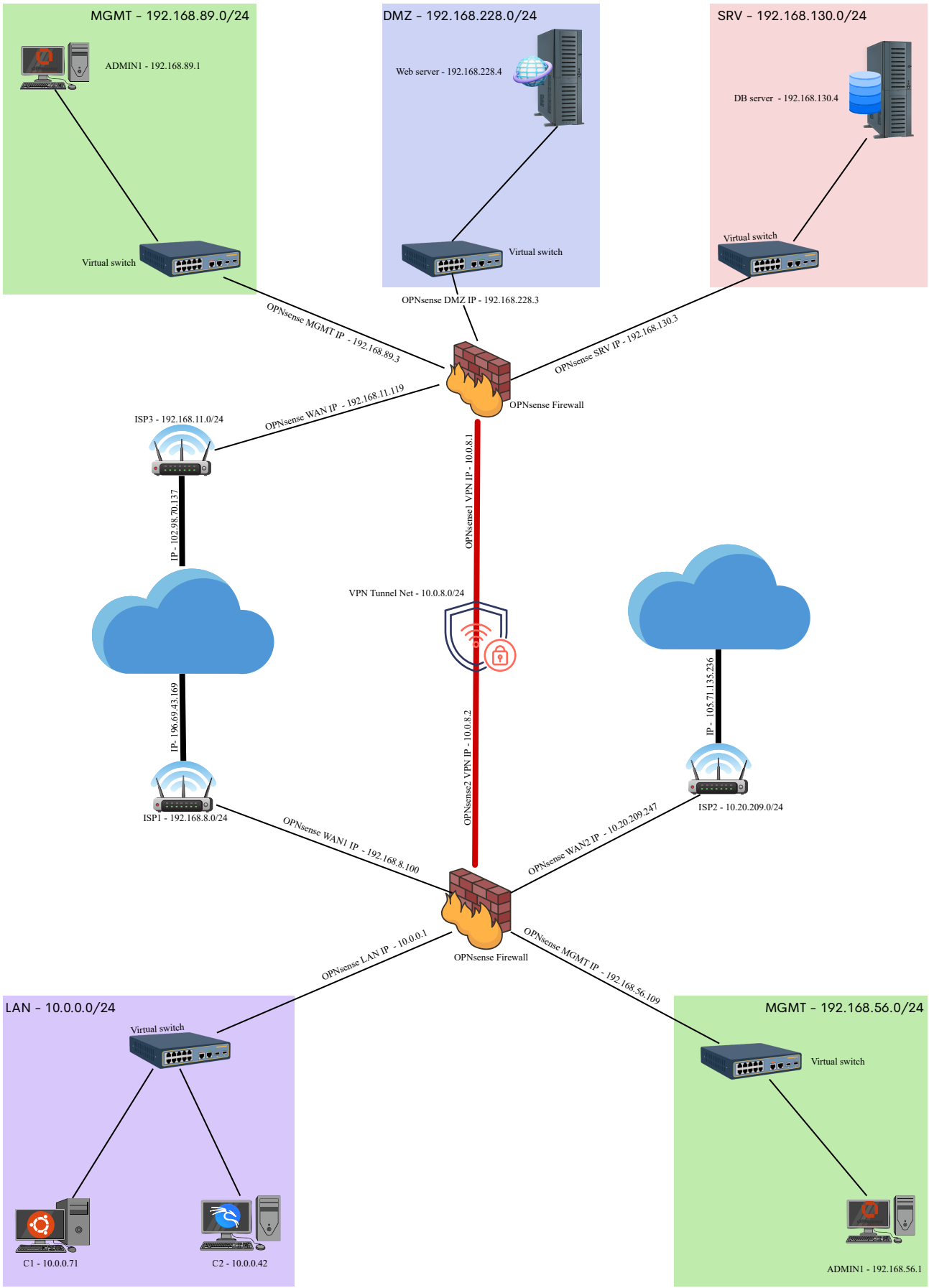


Figure 2 : Schéma topologique détaillé de l'architecture réseau multi-sites sécurisée

6. Politique de sécurité :

Dans le cadre de l'approche Zero Trust (Confiance Zéro) et de la Micro-segmentation, une politique de flux stricte a été définie pour régir les communications entre les différentes zones de l'architecture. Le principe fondamental appliqué est le "Deny by Default" (Tout ce qui n'est pas explicitement autorisé est bloqué).

Le tableau suivant présente la matrice conceptuelle des accès entre les principales zones de sécurité des deux sites :

Source	Destination	Type de Flux (Concept)	Action	Principe de Sécurité appliqué
Toute Zone externe	Réseaux Internes (LAN, MGMT, SRV)	Tout trafic non sollicité	Bloquer	Isolation : Blocage systématique des flux entrants depuis l'extérieur.
Internet (WAN)	DMZ (Site Distant)	Trafic Web Public	Autoriser	Exposition contrôlée : Accès limité aux services publics via un proxy inverse (Reverse Proxy).
Internet (WAN)	Pare-feu (Site Distant)	Distant)Trafic VPN	Autoriser	Interconnexion : Établissement du tunnel crypté Site-à-Site.
Réseau Utilisateurs (LAN)	Internet	Navigation Web & Tests	Filtrer	Contrôle d'accès : Navigation autorisée mais forcée à travers un Proxy de filtrage applicatif.
Réseau Utilisateurs (LAN)	Réseaux Partenaire (Site Distant)	Tout trafic	Bloquer	Segmentation : Les utilisateurs standards n'ont aucune visibilité sur l'infrastructure du partenaire.
Réseaux d'Administration (MGMT)	Pare-feux & Serveurs (Tous sites)	(Tous sites)Trafic de gestion	Autoriser	Administration centralisée : Accès total de bout en bout pour les administrateurs via le tunnel VPN.
Zone DMZ (Srv Web)	Zone SRV (Base de données)	Requêtes Backend (SQL)	Autoriser	Micro-segmentation : Le serveur frontal ne peut interagir qu'avec sa base de données attitrée.

Zone DMZ (Srv Web)	LAN, MGMT, Internet	Tout trafic	Bloquer	Confinement (Containment) : En cas de compromission de la DMZ, l'attaquant ne peut pas rebondir ailleurs.
Zone SRV (Bases de données)	Toute autre zone	Trafic initié par le SRV	Bloquer	Isolement profond : Les serveurs critiques sont purement passifs et ne peuvent pas initier de connexions vers l'extérieur.

Tableau 2 : Matrice de filtrage inter-zones

7. Conclusion :

Ce deuxième chapitre a permis d'établir le socle organisationnel et conceptuel du projet. L'adoption d'une méthodologie de travail structurée en binôme, couplée à une planification temporelle rigoureuse, a garanti une gestion de projet efficace et maitrisée. Par la suite, l'analyse fonctionnelle des besoins a conduit à la modélisation d'une architecture topologique segmentée et résiliente, centralisée autour de la passerelle OPNsense. Enfin, l'élaboration de la politique de sécurité et de la matrice de flux a permis de figer les règles d'accès inter-zones en appliquant de manière stricte le principe du moindre privilège.

Maintenant que la conception architecturale et les politiques de filtrage sont intégralement définies sur le plan théorique, le chapitre suivant s'attachera à décrire l'environnement de travail. Il détaillera les ressources matérielles ainsi que les technologies logicielles spécifiques qui ont été déployées pour concrétiser et virtualiser cette infrastructure.

Chapitre 3 :
Environnement de Travail et Technologies

1. Intoduction :

La mise en place d'une architecture réseau sécurisée et multi-sites nécessite une infrastructure matérielle et logicielle robuste. L'objectif de ce projet étant de concevoir un système complet à partir de zéro, l'utilisation de la virtualisation s'est imposée comme la solution optimale pour pallier l'absence d'équipements physiques d'entreprise (pare-feux matériels, commutateurs administrables, serveurs dédiés). Ce chapitre détaille l'ensemble de l'environnement de travail, justifiant les choix technologiques adoptés pour simuler, tester et valider notre architecture avec un haut degré de réalisme.

2. Environnement Matériel et Connectivité :

Pour supporter la charge de cette infrastructure virtualisée et reproduire des conditions de connectivité réelles, l'environnement physique repose sur deux composantes principales : les stations de travail et les équipements d'accès à Internet (FAI).

2.1. Les stations de travail (Hôtes) :

Le déploiement de la topologie a été réparti sur deux ordinateurs portables performants, agissant en tant que nœuds physiques distincts (simulant le "Site Principal" et le "Site Distant"). Ces machines hôtes disposent des ressources de calcul (CPU) et de mémoire (RAM) nécessaires pour exécuter simultanément plusieurs systèmes d'exploitation invités, garantissant ainsi la fluidité du routage et l'efficacité des traitements de sécurité en temps réel.



Figure 3 : Laptop icon

2.2. L'infrastructure de connectivité (Fournisseurs d'Accès Internet) :

Afin de valider les fonctionnalités avancées d'OPNsense (Load Balancing, Failover et interconnexion VPN), trois liaisons Internet distinctes ont été mobilisées :

- **Liaison Fibre Optique (Orange) :** Utilisée principalement pour le site hébergeant les services. Ce choix est stratégique car il permet de disposer d'une connectivité stable et, surtout, d'obtenir les prérequis nécessaires pour la configuration du serveur OpenVPN (interconnexion Site-à-Site).
- **Liaisons Mobiles 4G (IAM et Inwi) :** Utilisées sur le site principal pour simuler un environnement Multi-WAN. L'intégration de ces deux accès cellulaires distincts permet de tester concrètement la répartition de charge (Load Balancing) et la continuité de service en cas de panne de l'un des opérateurs (Failover).

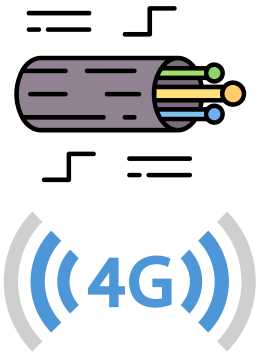


Figure 4: Faibre and 4G icon

3. Environnement de Virtualisation :

La création d'une architecture réseau complexe (incluant de multiples zones, pare-feux et serveurs) nécessite traditionnellement un investissement matériel lourd. Pour pallier cela, notre choix s'est porté sur la virtualisation.

Oracle VM VirtualBox (Hyperviseur de Type 2) :

Pour la mise en œuvre de notre laboratoire, nous avons opté pour VirtualBox dans sa dernière version. Bien qu'il s'agisse d'un hyperviseur de Type 2 (s'exécutant au-dessus d'un système d'exploitation hôte Windows ou Linux), il offre toute la souplesse nécessaire pour ce projet.



Figure 5 : Oracle Virtualbox logo

Justification du choix :

VirtualBox permet de créer des réseaux virtuels totalement isolés (Réseaux internes / Host-Only) agissant comme des commutateurs (switches) physiques virtuels. Cela nous a permis de segmenter l'infrastructure en plusieurs zones distinctes (LAN, DMZ, SRV, MGMT) sur une même machine physique sans aucun conflit de routage. De plus, sa compatibilité multiplateforme a facilité le travail collaboratif sur des hôtes Windows et Linux.

4. Systèmes d'Exploitation et Services Applicatifs :

L'infrastructure repose sur un écosystème hétérogène de systèmes d'exploitation, choisis spécifiquement pour répondre aux rôles qui leur sont attribués dans l'architecture globale.

4.1. Le Cœur du Réseau (OPNsense) :

Le rôle central de routage et de filtrage est assuré par OPNsense. Il s'agit d'une plateforme de pare-feu et de routage open-source basée sur FreeBSD.

Rôle : Il agit comme la passerelle de sécurité (Gateway) pour tous les réseaux. Nous l'avons choisi pour sa robustesse, sa modularité, et son interface d'administration graphique (GUI) intuitive qui facilite la gestion complexe des interfaces (Multi-WAN, VLANs virtuels) et des services de sécurité.



Figure 6 : OPNsense Logo

4.2. Les Systèmes Clients (Zone LAN) :

Pour simuler l'activité des utilisateurs finaux au sein du réseau local (LAN), deux distributions Linux ont été déployées :

- **Lubuntu :** Une distribution légère choisie pour simuler un poste de travail standard sans consommer de ressources excessives sur l'hyperviseur. Elle permet de tester la navigation Web à travers le proxy et de vérifier l'accès à Internet.
- **Kali Linux :** Une distribution spécialisée dans la sécurité offensive. Son intégration dans le LAN est stratégique : elle nous sert d'outil de diagnostic avancé pour tester l'étanchéité de nos propres règles de pare-feu (Firewall Rules) et vérifier les réactions du système de détection d'intrusion (IDS) face à des paquets malveillants simulés.



Figure 7 : Lubuntu logo



Figure 8 : Kali logo

4.3. Les Systèmes Serveurs (Zones DMZ & SRV) :

Pour reproduire une architecture d'entreprise multiniveaux (N-Tier), les services ont été séparés et isolés sur des serveurs distincts exécutant Ubuntu Server. Ce système d'exploitation sans interface graphique constitue le standard de l'industrie pour l'hébergement de services en raison de sa stabilité et de sa légèreté.

- Serveur Web (Zone DMZ) : Héberge le service applicatif Apache Tomcat. Il constitue la vitrine publique du réseau, accessible depuis l'extérieur via une redirection de port (Port Forwarding) ou un Proxy Inverse configuré sur le pare-feu OPNsense.
- Serveur de Base de données (Zone SRV) : Héberge le système de gestion de base de données relationnelle MariaDB. Il est placé dans une zone hautement sécurisée et isolée. Les données qu'il contient ne sont accessibles que via des requêtes légitimes provenant exclusivement du serveur Web (DMZ), empêchant ainsi toute compromission directe depuis l'extérieur ou depuis le réseau local (LAN).

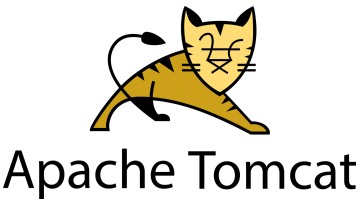


Figure 9 : Apache Tomcat logo



Figure 10 : Maria DB logo

5. Technologies et Outils de Sécurité :

La robustesse de l'architecture ne repose pas uniquement sur la segmentation réseau, mais également sur l'intégration de progiciels de sécurité avancés au sein d'OPNsense, ainsi que sur l'utilisation d'outils d'audit externes.

5.1. OpenVPN (Tunneling et Chiffrement) :

OpenVPN est une solution logicielle open-source permettant de créer des réseaux privés virtuels (VPN) sécurisés de bout en bout.

- Rôle dans le projet : Il a été déployé en mode "Site-à-Site" pour interconnecter l'infrastructure locale (Site Principal) au serveur distant hébergeant les services. Il crée un tunnel crypté (sous-réseau 10.0.8.0/24) à travers le réseau public des FAI, garantissant la confidentialité et l'intégrité des données échangées entre les deux pare-feux, tout en échappant à l'inspection des fournisseurs d'accès.



Figure 11 : OpenVpn logo

5.2. Suricata (Système de Détection et Prévention d'Intrusion - IDS/IPS) :

Suricata est un moteur open-source d'analyse de menaces réseau haute performance. Contrairement à un pare-feu classique qui bloque les ports, Suricata analyse le contenu (la charge utile) des paquets en temps réel.

- Rôle dans le projet : Intégré directement dans OPNsense, il agit comme le bouclier actif du réseau. Il a été configuré pour surveiller les flux entrants vers la DMZ (Serveur Web) et les flux sortants du LAN. Grâce à des règles personnalisées, il est capable de détecter des signatures d'attaques connues (ex: tentatives d'injection SQL) et de bloquer l'IP source dynamiquement.



Figure 12 : Suricata logo

5.3. Squid Proxy (Filtrage et Contrôle d'Accès Web) :

Squid est un serveur mandataire (Proxy) avec des capacités de mise en cache hautes performances pour les clients Web.

- Rôle dans le projet : Déployé en mode transparent pour la zone LAN, Squid agit comme un intermédiaire entre les postes utilisateurs (Lubuntu) et Internet. Il permet d'appliquer une politique de filtrage URL stricte (blocage de sites malveillants ou non autorisés) et d'optimiser la bande passante en mettant en cache les requêtes fréquentes.



Figure 13 : Squid logo

5.4. Outils d'Audit, d'Administration et de Test :

Pour valider l'efficacité des politiques de sécurité et configurer les serveurs de manière approfondie, plusieurs outils annexes ont été exploités :

- **Nmap (Network Mapper) :** Exécuté depuis la machine "Kali Linux" située dans le LAN, cet outil de balayage de ports a été utilisé pour réaliser des tests de pénétration internes. Il a permis de vérifier concrètement que les règles "Deny All" étaient fonctionnelles et que seuls les ports autorisés (ex: 80, 443, 3306) répondaent.
- **FileZilla (Protocole SFTP) :** Utilisé depuis les machines d'administration (Réseaux MGMT) pour transférer de manière sécurisée des fichiers de configuration complexes, notamment les règles personnalisées (Custom Rules) pour Suricata et les pages web vers le serveur Apache (DMZ).

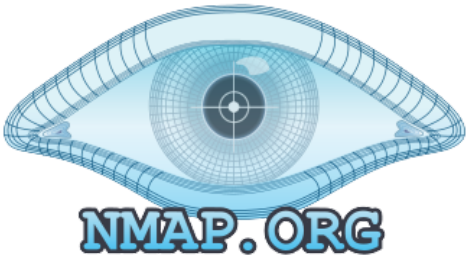


Figure 14 : Nmap logo



Figure 15 : FileZilla

5.5. Outils de Modélisation et de Conception :

- **Canva :** Outil de conception graphique utilisé pour la modélisation topologique du réseau. Il a permis de produire des schémas architecturaux clairs, normés et professionnels, facilitant la compréhension de la séparation des zones (VLANs, Multi-WAN, interconnexions) pour la rédaction de ce rapport.



Figure 16 : Canva logo

6. Conclusion :

Ce troisième chapitre a permis de détailler l'environnement complet de travail ayant servi de base à la réalisation du projet. Le choix d'une architecture virtualisée sous VirtualBox, couplée à l'utilisation stratégique de distributions Linux (Lubuntu, Kali, Ubuntu Server) et du système pare-feu OPNsense, a permis de simuler une infrastructure d'entreprise réaliste malgré les contraintes matérielles. L'ajout de briques logicielles expertes telles que Suricata, Squid et OpenVPN vient renforcer ce socle. À présent que l'environnement matériel et logiciel est défini, le chapitre suivant sera consacré à la phase pratique : l'implémentation, la configuration technique et les tests de validation de ces différentes solutions.

Chapitre 4 :
Implémentation et Réalisation Technique

1. Intoduction :

Ce chapitre présente la mise en œuvre technique de l'architecture réseau sécurisée définie précédemment. Il décrit les étapes de déploiement dans l'environnement virtualisé, depuis la préparation des machines sous VirtualBox jusqu'à la configuration des services essentiels d'OPNsense. Nous y détaillons notamment la mise en place du Multi-WAN, l'établissement du tunnel VPN Site-à-Site, ainsi que l'application des règles de pare-feu assurant la micro-segmentation et le respect du principe Zero Trust. Enfin, ce chapitre couvre l'intégration des couches de sécurité applicatives telles que le proxy Squid et le moteur IDS/IPS Suricata, avant de passer aux tests et à la validation dans le chapitre suivant.

2. Préparation et Configuration Initiale des Équipements :

fin de simuler un environnement de production réaliste, l'ensemble de l'infrastructure a été déployé sur l'hyperviseur Oracle VM VirtualBox. Cette approche a permis de modéliser fidèlement la ségrégation des réseaux physiques à l'aide d'adaptateurs virtuels spécifiques.

2.1 Déploiement des machines virtuelles (Hyperviseur) :

L'infrastructure globale est divisée en deux environnements distincts, chacun géré par sa propre instance OPNsense. Les ressources matérielles ont été allouées de manière à garantir la fluidité du traitement des paquets.

A. Le Site Principal (Accès Utilisateurs et Multi-WAN) :

Le pare-feu OPNsense de ce site a été provisionné avec 3 Go de RAM et 2 cœurs de processeur. Il gère l'accès des postes clients et dispose d'une configuration réseau à quatre interfaces pour assurer la haute disponibilité.

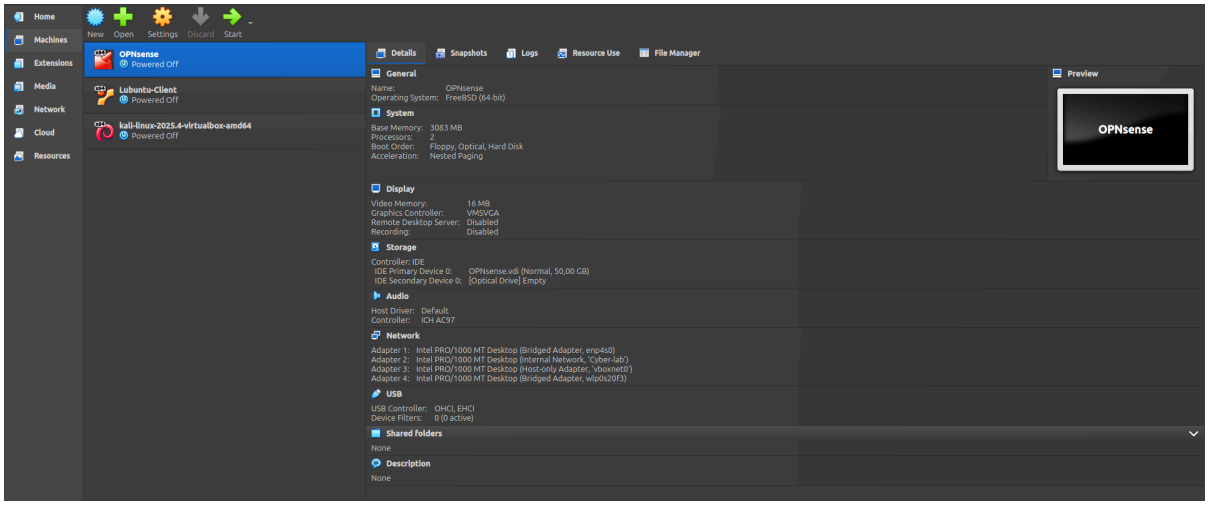


Figure 17 : Déploiement des machines virtuelles et ressources allouées au pare-feu du Site principale.

B. Le Site Distant (Hébergement et Serveurs) :

Le pare-feu du site distant, ayant la charge de protéger les serveurs backend et d'héberger le serveur VPN, a été provisionné avec 6 Go de RAM et 2 cœurs. Il gère les serveurs critiques isolés en zones spécifiques.

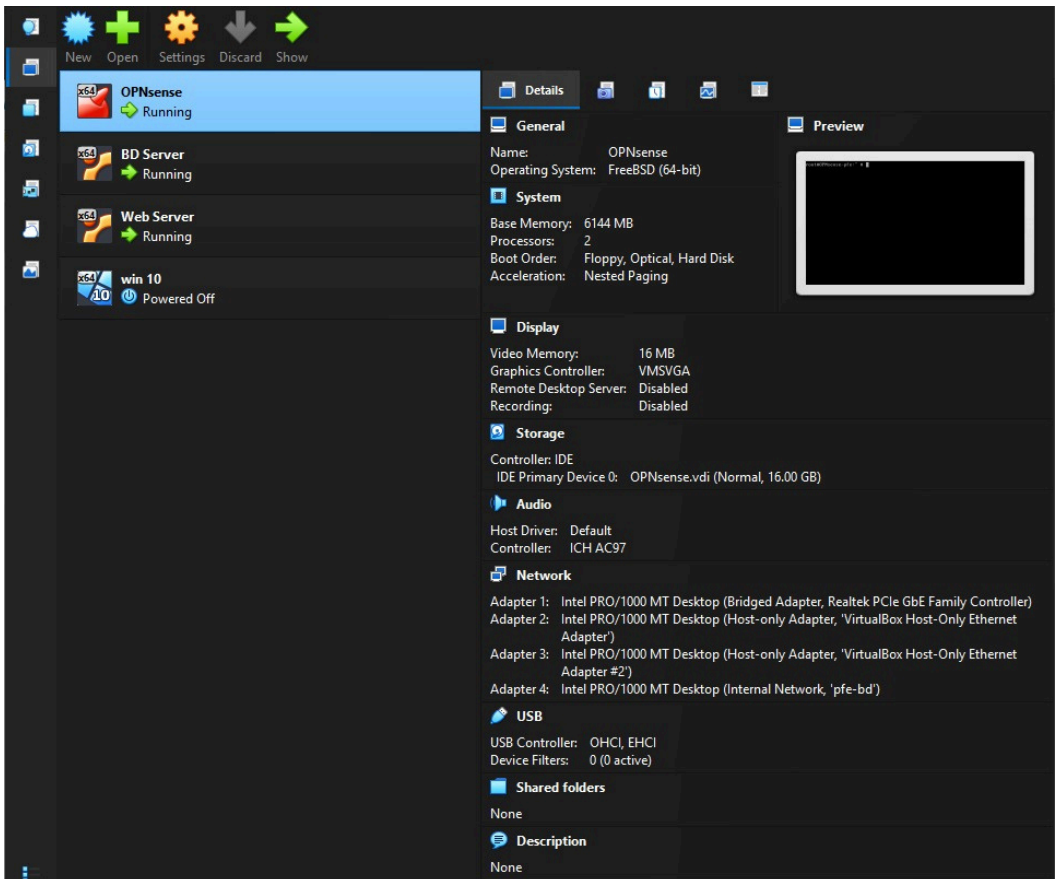


Figure 18 : Déploiement des machines virtuelles et ressources allouées au pare-feu du Site Partenaire.

2.2 Configuration matérielle des interfaces réseau (VirtualBox) :

La sécurité de l'architecture repose sur l'isolation physique simulée par l'hyperviseur.

- **Sur le Site Principal :** Quatre cartes réseau ont été activées : deux en mode "Accès par pont" (représentant les connexions WAN1 et WAN2), une en mode "Réseau interne" (LAN utilisateurs isolés), et une en "Réseau privé hôte" dédiée à l'administration (OPT1/MGMT).
- **Sur le Site Distant :** La configuration reflète son rôle de centre d'hébergement : une interface en "Accès par pont" (WAN), deux interfaces en "Réseau privé hôte" (réseau d'administration LAN/MGMT et zone DMZ), et une interface en "Réseau interne" pour la zone hautement sécurisée de la base de données (SRV).

2.3 Attribution et adressage IP :

Le plan d'adressage IP a été rigoureusement défini via la console FreeBSD pour segmenter les flux et garantir l'absence de chevauchement (overlap) entre les sous-réseaux des deux sites, condition indispensable pour le routage VPN.

- **Adressage du Site Principal :** Les interfaces WAN/WAN2 assurent la connectivité externe. Le réseau local (LAN) est déployé sur la plage 10.0.0.1/24. L'interface d'administration (OPT1) est isolée sur le réseau 192.168.56.0/24.

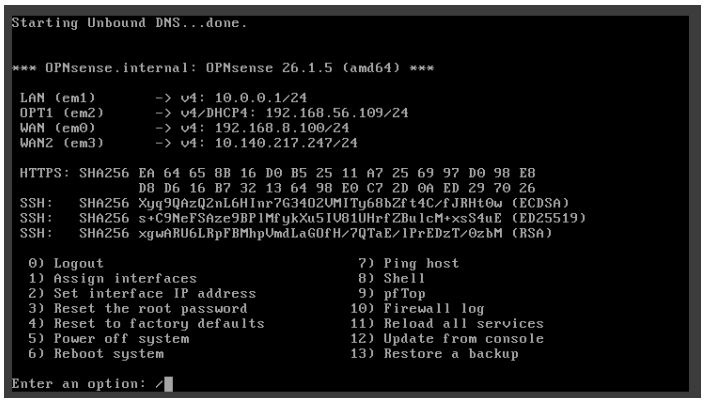


Figure 19 : Assignation des interfaces et adressage IP du pare-feu principal.

- **Adressage du Site Distant :** Le réseau d'administration (LAN/MGMT) est isolé sur 192.168.89.3/24. Les services exposés au public sont confinés dans la DMZ (192.168.228.3/24), tandis que la zone des bases de données (SRV) opère sur 192.168.130.3/24.

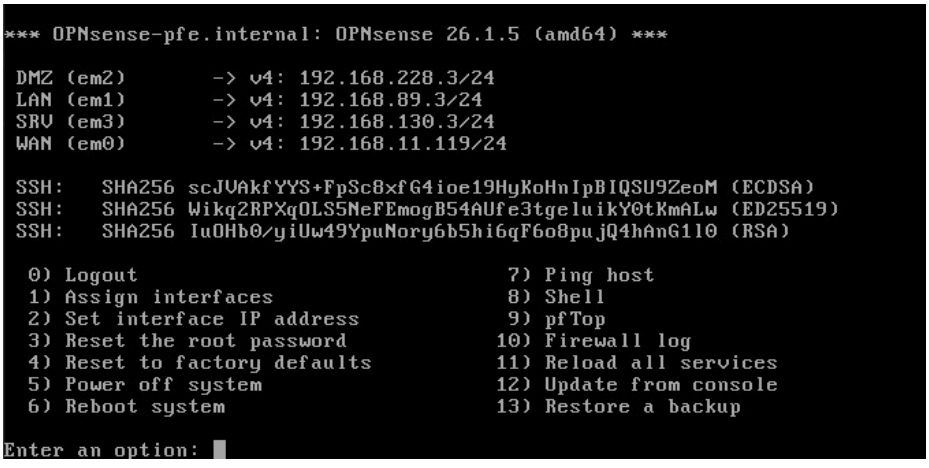


Figure 20 : Assignation des interfaces et adressage IP du pare-feu distant.

2.4. Sécurisation des accès d'administration :

Afin de protéger le plan de contrôle (Control Plane) de l'infrastructure, une politique de durcissement (hardening) stricte et identique a été appliquée sur les deux pare-feux. L'objectif est de réduire la surface d'attaque et d'empêcher la compromission des consoles de gestion.
L'utilisation du protocole HTTPS a été forcée, renforcée par l'activation du paramètre HTTP Strict Transport Security (HSTS) pour prévenir les attaques par interception. Surtout, le champ d'écoute du service web (Listen Interfaces) a été restreint exclusivement aux interfaces de gestion dédiées. Il convient de préciser que, bien que le système OPNsense attribue par défaut les noms "OPT1" (pour le Site Principal) et "LAN" (pour le Site Distant) à ces interfaces, elles assument toutes deux le rôle exclusif de réseau d'administration et sont unifiées sous la nomenclature professionnelle "MGMT" (Management) au sein de cette architecture. En restreignant l'écoute du pare-feu uniquement à ces réseaux MGMT, le portail d'administration est rendu totalement inaccessible depuis les réseaux des utilisateurs standards ou depuis Internet, validant ainsi la première étape de l'approche "Zero Trust".

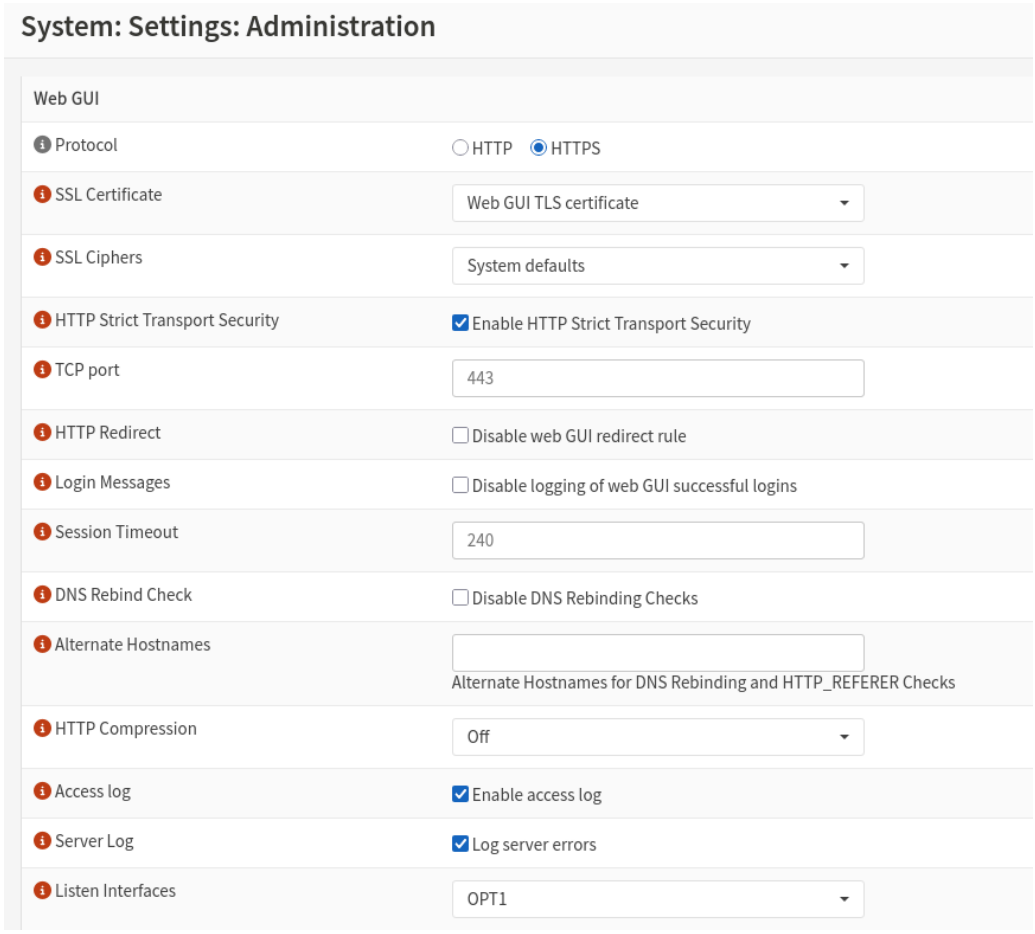


Figure 21 : Configuration sécurisée de l'interface graphique (Web GUI) limitant l'accès au réseau de management.

3. Gestion du Routage et Haute Disponibilité (Multi-WAN) :

La continuité de service et l'optimisation des ressources réseau sont des exigences fondamentales de cette architecture. L'infrastructure intègre une politique stricte de qualité de service (QoS) pour réguler la consommation du réseau interne, ainsi que des mécanismes de redondance de liens pour assurer une connectivité ininterrompue.

3.1. Configuration du contrôle de bande passante (Traffic Shaping) :

Afin de garantir que les flux critiques, tels que le tunnel VPN Site-à-Site ou le trafic d'administration, ne souffrent d'aucune congestion, une politique de limitation de bande passante (Traffic Shaping) a été mise en place pour les utilisateurs du réseau local (LAN).
La configuration a été réalisée via le module Firewall: Shaper d'OPNsense (basé sur le moteur performant ipfw/dummynet), en appliquant les règles de classification directement sur l'interface WAN. Cette approche centralisée permet de réguler le trafic entrant et sortant au point même de la connexion Internet. La mise en œuvre s'est déroulée en deux étapes distinctes :

Étape 1 : Création des "Pipes" (Tuyaux d'étranglement) :

Des "Pipes" ont été configurés pour définir les limites physiques absolues imposées au trafic utilisateur. Deux tuyaux ont été créés pour séparer les flux :

- Un pipe dédié au téléchargement (Download), limité à 5 Mbit/s.
- Un pipe dédié au téléversement (Upload), également limité à 5 Mbit/s.

L'utilisation de masques (destination pour le téléchargement et source pour l'upload) assure que cette limitation s'applique de manière précise, en analysant le trafic en fonction des adresses IP d'origine et de destination appartenant au réseau interne.

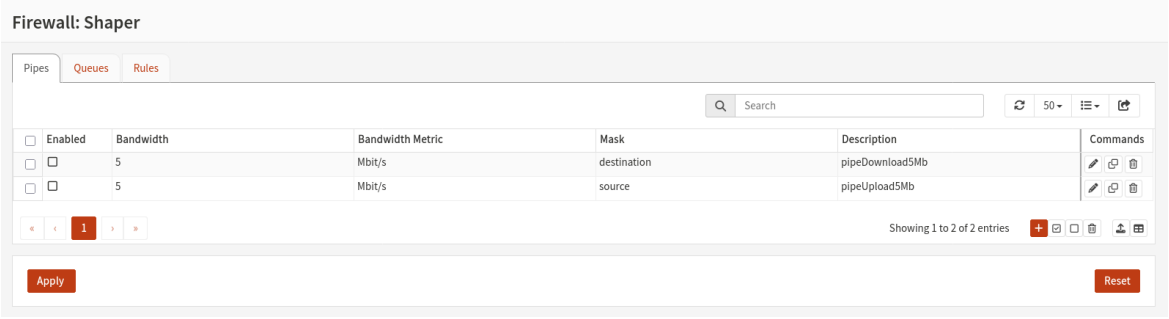


Figure 22 : Configuration des limites physiques de bande passante (Pipes) à 5 Mbit/s.

Étape 2 : Application des règles de classification (Rules) :

Une fois les limites définies, des règles d'interception ont été appliquées sur l'interface WAN pour capturer le trafic du sous-réseau utilisateur (10.0.0.0/24) et l'injecter dans les "Pipes" appropriés :

- Le trafic en provenance d'Internet et destiné au sous-réseau LAN (téléchargement) est intercepté et bridé par le pipeDownload5Mb.
- Le trafic provenant du sous-réseau LAN et destiné à Internet (téléversement) est intercepté et bridé par le pipeUpload5Mb.

Cette ségrégation stricte garantit que les postes clients finaux ne pourront en aucun cas saturer la liaison montante ou descendante globale de l'entreprise.

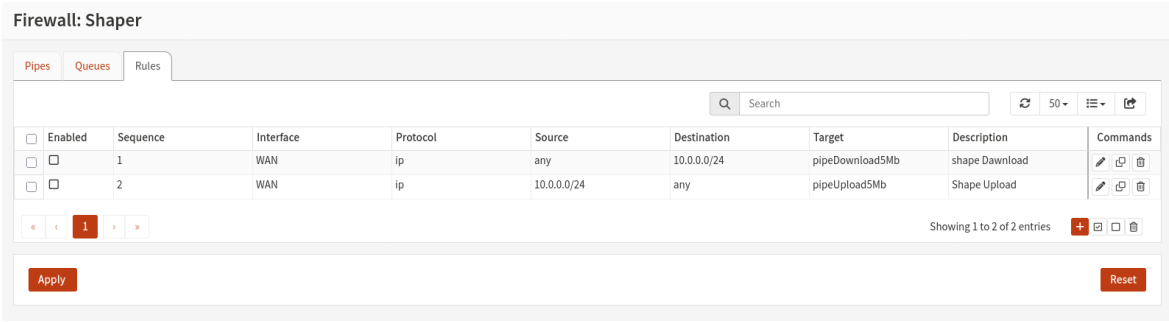


Figure 23 : Application des règles d'interception de trafic sur l'interface WAN.

3.2. Implémentation de la Haute Disponibilité (Failover) et de la Répartition de Charge (Load Balancing) :

Pour garantir une connectivité ininterrompue vers Internet, l'architecture du Site Principal exploite deux liaisons distinctes (WAN1 et WAN2). La gestion de ces multiples accès repose sur la création de groupes de passerelles (Gateway Groups) au sein d'OPNsense, où le comportement du routage est dicté par des niveaux de priorité appelés Tiers (le niveau 1 étant la priorité la plus haute).

La configuration s'est articulée autour de deux stratégies de routage distinctes, applicables selon les besoins de l'infrastructure :

A. Configuration de la Tolérance de panne (Failover) :

Le mode Failover (basculement automatique) opère selon une architecture de type Actif/Passif. L'objectif est de maintenir tout le trafic sur une ligne principale et de ne basculer sur la ligne secondaire qu'en cas de défaillance. Pour ce faire, un groupe de passerelles nommé "FailOver" a été défini. La passerelle principale (WAN_GW) a été configurée avec une priorité absolue (Tier 1), tandis que la passerelle de secours (WAN2_Getway) a été reléguée au niveau inférieur (Tier 2). Le déclencheur de basculement (Trigger Level) a été configuré sur "Packet Loss" (perte de paquets). Ainsi, le pare-feu surveille la ligne principale en continu et redirige automatiquement les flux vers la ligne secondaire dès qu'une dégradation du signal est détectée.

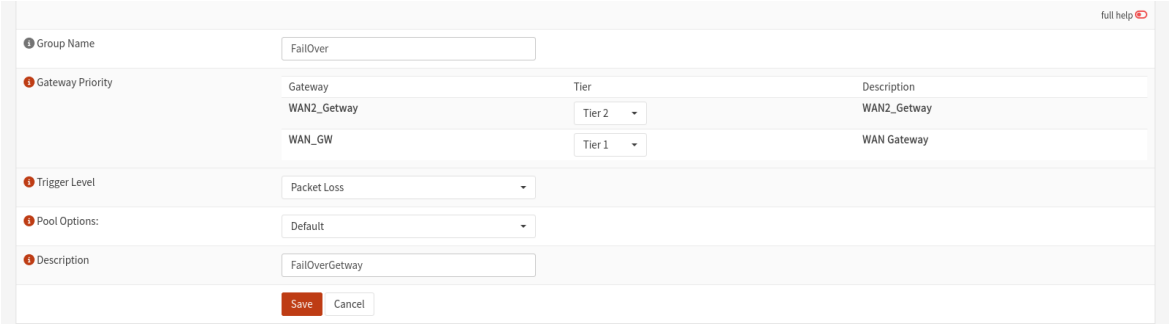


Figure 24 : Configuration du groupe de passerelles en mode Failover (Actif/Passif).

B. Configuration de la Répartition de charge (Load Balancing) :

Le mode Load Balancing opère selon une architecture de type Actif/Actif. L'objectif est de maximiser la bande passante globale en agrégeant la capacité des deux liaisons Internet simultanément. Dans cette configuration, un second groupe de passerelles nommé "LoadBalancing" a été créé. La différence architecturale majeure réside dans l'attribution des priorités : les deux passerelles (WAN_GW et WAN2_Getway) ont été assignées au même niveau de priorité (Tier 1). En les plaçant sur un pied d'égalité, le moteur de routage d'OPNsense distribue les nouvelles connexions sortantes (trafic LAN vers Internet) de manière équilibrée sur les deux interfaces, optimisant ainsi les performances réseau globales.

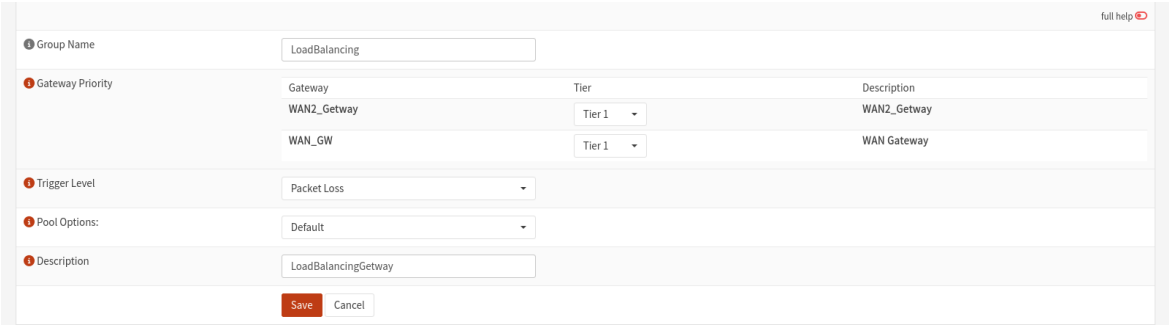


Figure 25 : Configuration du groupe de passerelles en mode Load Balancing (Actif/Actif).

4. Déploiement du Tunnel VPN Site-à-Site (OpenVPN) :

Pour interconnecter les réseaux internes des deux sites de manière sécurisée à travers Internet, un tunnel VPN (Virtual Private Network) de type Site-à-Site a été déployé. Le protocole OpenVPN a été retenu pour sa robustesse, sa flexibilité et son support natif sur les plateformes OPNsense.

4.1. Infrastructure à Clés Publiques (PKI) et Certificats :

La sécurité, l'authentification et le chiffrement du tunnel reposent sur une Infrastructure à Clés Publiques (PKI) stricte, garantissant qu'aucune entité non autorisée ne puisse s'intégrer à l'architecture.

Le Site Distant ayant été désigné pour agir en tant que nœud central (Serveur), une Autorité de Certification (CA) interne, nommée CA_VPN_Entreprise, y a été générée. Cette autorité a permis d'émettre et de signer numériquement les certificats nécessaires à l'établissement du tunnel :

- Un certificat serveur (Cert_Serveur_VPN) utilisé par l'instance OpenVPN pour prouver son identité.
- Un certificat client (Cert_Client_user_vpn / VPN client), généré par la CA du serveur, puis exporté et importé de manière sécurisée sur le pare-feu du Site Principal.

Cette méthode assure une authentification mutuelle forte (Mutual TLS) : le client vérifie l'identité du serveur, et le serveur n'accepte que les clients possédant un certificat cryptographique valide signé par son autorité. (Note : Les autres certificats visibles sur les captures, tels que ceux dédiés au portail Web ou à la DMZ, sont gérés indépendamment et n'interviennent pas dans la logique de ce tunnel VPN).

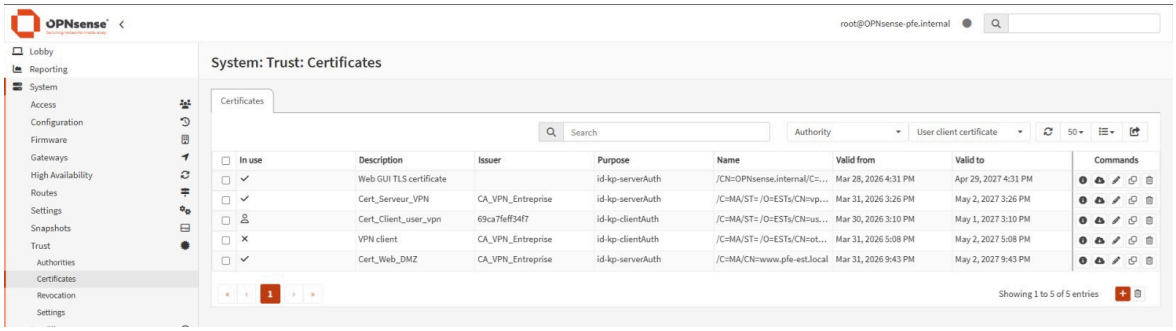


Figure 26 : Gestionnaire de certificats sur le Site Distant (Serveur), montrant la CA et les certificats VPN générés.

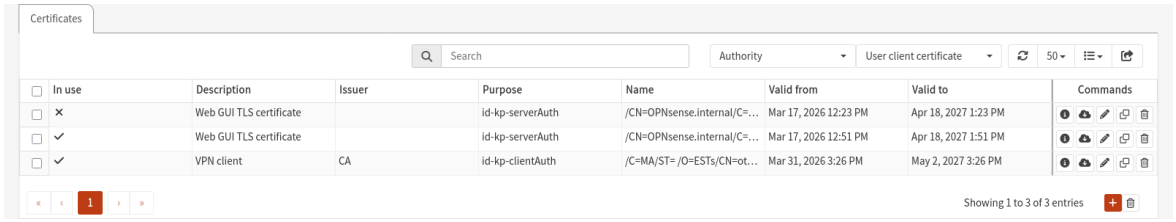


Figure 27 : Importation du certificat client et de l'autorité de certification sur le Site Principal.

4.2. Configuration des Instances OpenVPN (Serveur et Client) :

L'architecture de communication retenue suit un modèle Client/Serveur. Le tunnel opère en mode de routage (interface de type TUN), ce qui permet d'encapsuler et d'acheminer des paquets IP de couche 3 entre les différents sous-réseaux (LAN, MGMT, DMZ, SRV) selon les règles de pare-feu définies.

A. Configuration de l'instance Serveur (Site Distant) :

Une instance OpenVPN a été créée avec le rôle "Serveur". Elle est configurée pour écouter en permanence les requêtes entrantes sur l'interface WAN (généralement via le port UDP 1194). Cette instance s'appuie sur le certificat Cert_Serveur_VPN et définit la topologie de routage interne pour permettre au trafic provenant du tunnel d'atteindre les zones isolées (SRV, DMZ, MGMT).

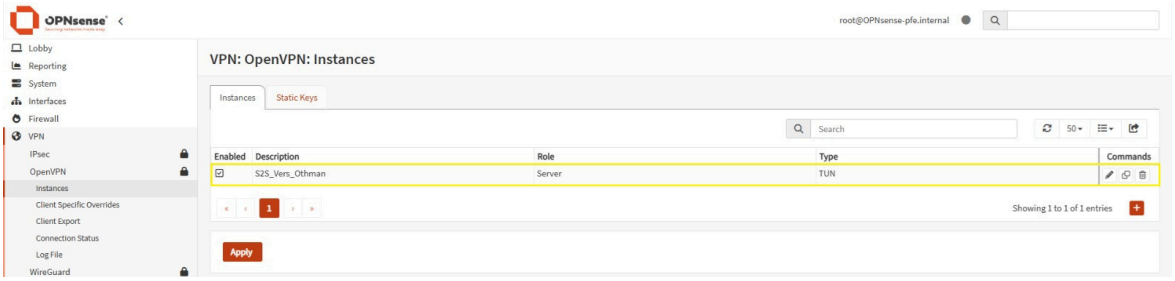


Figure 28 : Déploiement de l'instance OpenVPN en mode "Serveur" (TUN) sur le Site Distant.

B. Configuration de l'instance Client (Site Principal) :

En miroir, une instance OpenVPN a été configurée avec le rôle "Client" sur le Site Principal. Son comportement est d'initier activement une connexion chiffrée vers l'adresse IP publique (WAN) du Site Distant. Cette instance utilise le certificat client préalablement importé pour s'authentifier et s'intégrer au réseau superposé (Overlay Network).

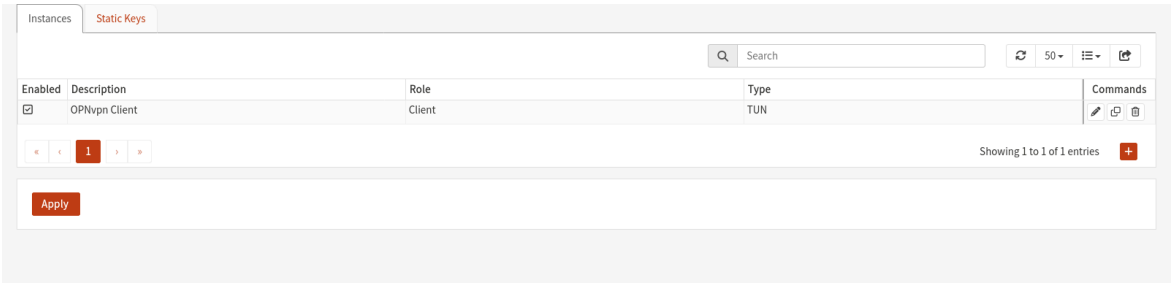


Figure 29 : Déploiement de l'instance OpenVPN en mode "Client" (TUN) sur le Site Principal.

5. Implémentation de la Politique de Sécurité "Zero Trust" :

La traduction de la matrice de flux théorique en règles de pare-feu opérationnelles constitue le cœur sécuritaire de l'infrastructure. L'implémentation a suivi le principe du "Zero Trust" (Confiance Zéro) et de la micro-segmentation. Dans OPNsense, le filtrage s'opère selon le principe du "First-Match" (la première règle qui correspond au trafic est appliquée). L'ordre des règles est donc critique pour garantir l'efficacité de l'isolation.
Cette section détaille le durcissement (hardening) des interfaces, en commençant par le Site Principal.

5.1. Sécurisation du Site Principal (Pare-feu Client) :

Le Site Principal agit en tant que client VPN et héberge les utilisateurs standards ainsi que les administrateurs locaux. La politique appliquée y est extrêmement restrictive.

A. Interfaces Externes (WAN et WAN2) :

Conformément aux meilleures pratiques de sécurité, les interfaces exposées à Internet (WAN et WAN2) ne comportent aucune règle d'autorisation explicite. OPNsense opérant comme un pare-feu à états (Stateful Firewall), tout le trafic entrant non sollicité est bloqué par la règle implicite "Deny by Default". Le tunnel VPN étant initié depuis l'intérieur vers le Site Distant, le pare-feu autorise dynamiquement le trafic de retour sans nécessiter l'ouverture de ports en entrée.

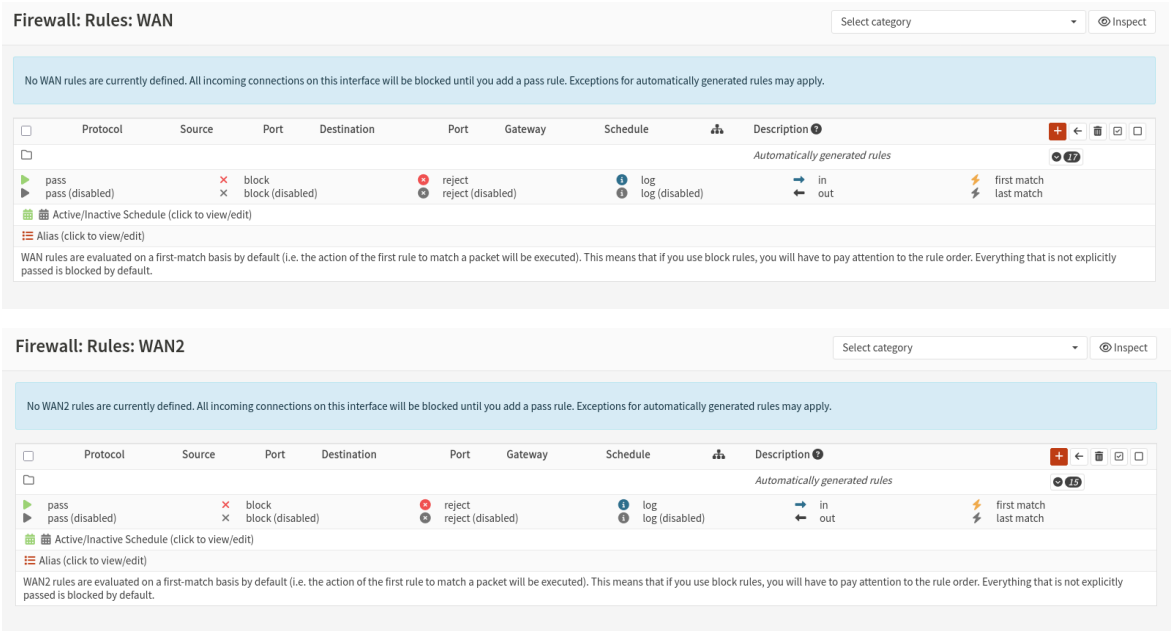


Figure 30 : Interfaces WAN et WAN2 sans règle entrante, appliquant un blocage par défaut strict.

B. Réseau Utilisateurs (Interface LAN) :

L'interface LAN regroupe les postes de travail standards. La stratégie implémentée empêche ces utilisateurs d'accéder aux ressources sensibles tout en maintenant les services essentiels. L'ordre des règles a été architecturé comme suit :

- Services critiques (DNS et NTP) : Autorisation des requêtes DNS (Port 53) et de synchronisation horaire (Port 123) vers le pare-feu local. Ces règles sont placées au sommet pour éviter qu'elles ne soient interceptées par les règles de blocage suivantes.
- Protection de l'infrastructure : Blocage explicite de tout accès à l'interface d'administration du pare-feu (Block gui acces).
- Isolation inter-sites : Blocage de l'accès aux réseaux du Site Distant (Partner_MGMT_Net, DMZ, SRV) afin d'assurer qu'un utilisateur standard ne puisse pas interagir avec l'infrastructure partenaire.
- Accès contrôlé vers l'extérieur : Autorisation du trafic Web (TCP 80/443) et ICMP (Ping) vers l'Internet.
- Isolation finale : Une règle explicite de blocage total (Lan isolation) conclut la liste pour intercepter toute anomalie.

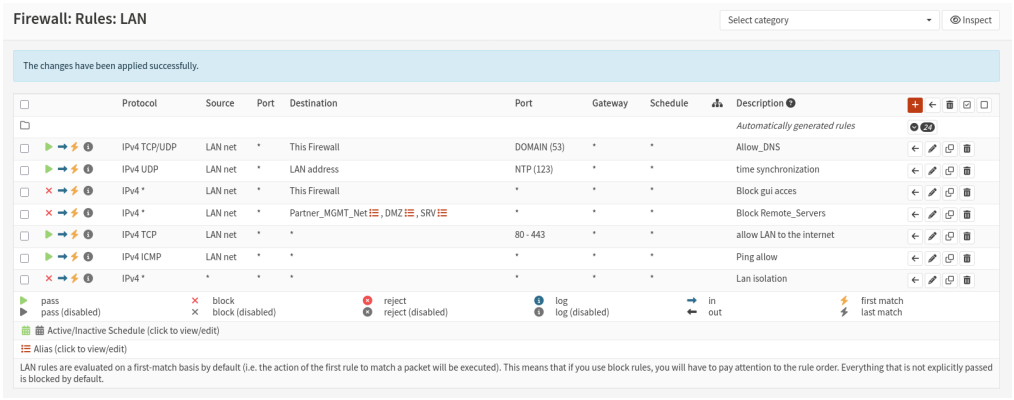


Figure 31 : Règles de l'interface LAN illustrant l'isolation des utilisateurs et l'accès restreint.

C. Réseau d'Administration (Interface OPT1 / MGMT) :

L'interface OPT1, désignée comme le réseau de gestion (MGMT), bénéficie de privilèges étendus nécessaires à l'administration de l'infrastructure complète. Les règles autorisent la résolution DNS et l'accès à l'interface graphique (HTTPS 443) du pare-feu local. De plus, une règle de privilège administratif (Admin privilege allow) autorise le trafic vers toutes les zones critiques du Site Distant (Réseau d'administration partenaire, DMZ, et SRV). Une règle de blocage par défaut ferme la chaîne pour isoler ce réseau de tout trafic non sollicité.

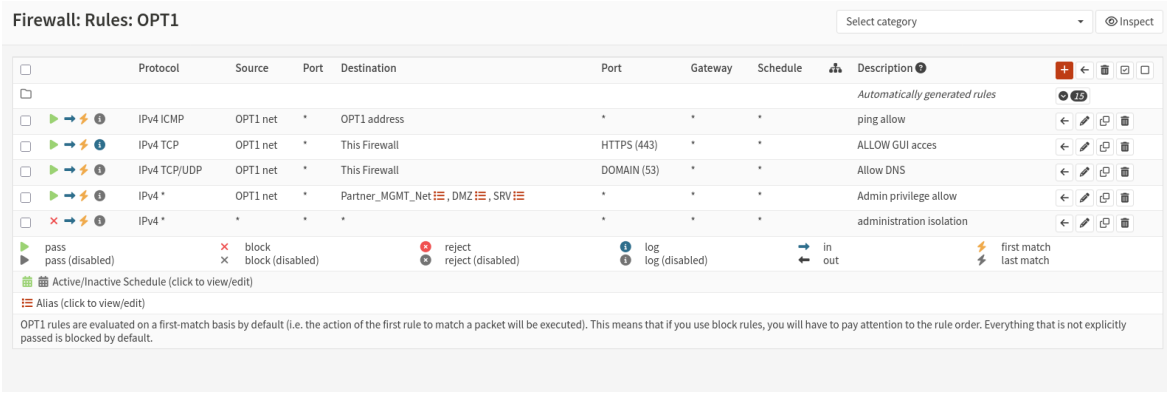


Figure 32 : Règles de l'interface OPT1 (MGMT) autorisant l'administration locale et inter-sites.

D. Interface Tunnel (OpenVPN) :

Cette interface contrôle le trafic entrant à travers le tunnel VPN crypté, provenant exclusivement du réseau d'administration du partenaire (Partner_MGMT_Net). L'application stricte du contrôle d'accès basé sur les rôles (RBAC) est visible ici :

- L'administrateur distant est autorisé à accéder au réseau de gestion local (OPT1 net) pour la maintenance des équipements terminaux.
- Un accès total au pare-feu lui-même (This Firewall) lui est accordé pour l'administration croisée.
- Une règle d'isolation stricte bloque tout autre flux sortant du tunnel, protégeant ainsi le réseau LAN des utilisateurs de toute intrusion via le VPN.

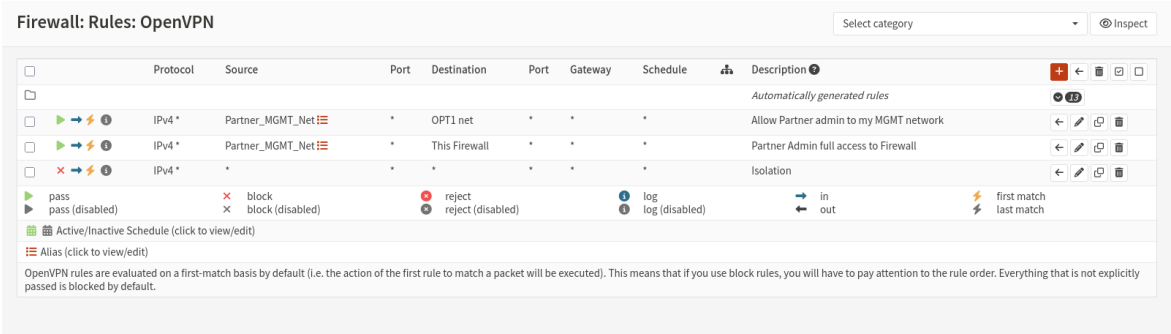


Figure 33 : Règles de l'interface OpenVPN contrôlant l'accès entrant de l'administrateur distant.

5.2. Sécurisation du Site Distant (Pare-feu Serveur et Hébergement) :

Le Site Distant hébergeant les serveurs de production ainsi que l'instance VPN Serveur, sa politique de filtrage met en évidence une application rigoureuse de la micro-segmentation. Chaque zone est strictement isolée et ne communique qu'à travers des flux explicitement autorisés.

A. Interface Externe (WAN) :

Contrairement au site client, l'interface WAN du Site Distant doit accepter certaines requêtes entrantes pour assurer la disponibilité des services. Les règles ont été architecturées pour minimiser la surface d'attaque :

- Prévention d'intrusion (GeoIP) : La première règle intercepte et bloque instantanément tout trafic provenant de pays répertoriés comme hostiles ou non pertinents (Block_GeoIP). Placée en tête de liste, elle préserve les ressources du pare-feu.
- Ouverture des services : Seuls deux flux légitimes sont autorisés à pénétrer le réseau : le trafic UDP sur le port 1194 pour l'établissement du tunnel VPN, et le trafic TCP sur le port 443 dirigé vers le pare-feu local, où un Reverse Proxy (HAProxy) se charge de relayer de manière sécurisée les requêtes vers le serveur Web en DMZ.
- Blocage par défaut : Toute autre tentative de connexion est rejetée et journalisée.

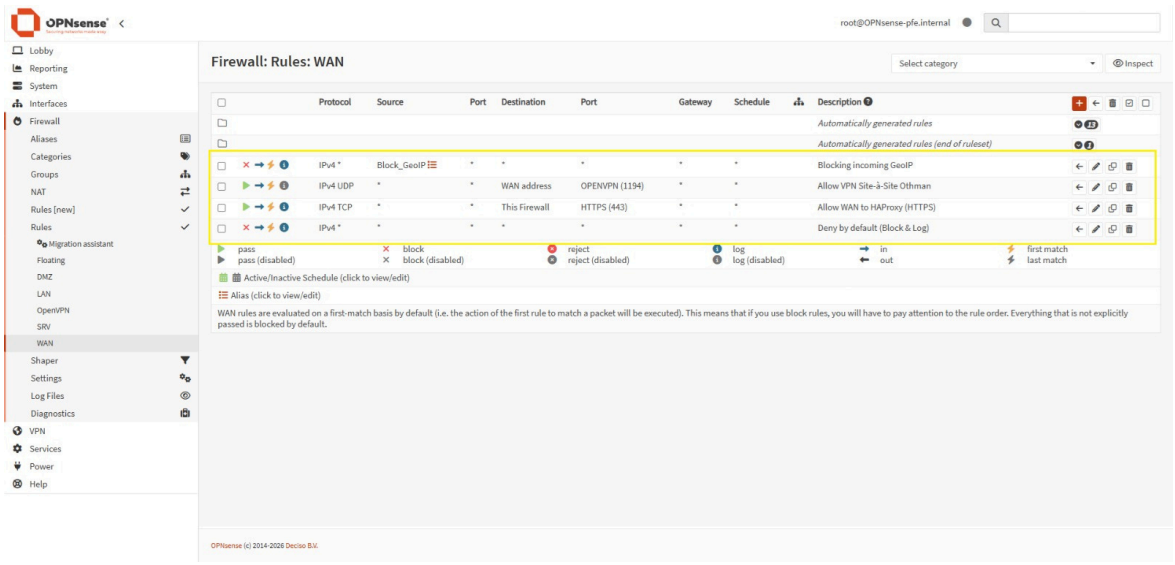


Figure 34 : Règles de l'interface WAN intégrant le filtrage géographique (GeoIP) et l'exposition contrôlée des services.

B. Réseau d'Administration (Interface LAN / MGMT) :

Bien que nommée "LAN" par défaut par le système, cette interface agit comme le réseau d'administration (MGMT) du Site Distant. L'architecture des règles force l'application des politiques de sécurité locales :

- Services de base : Autorisation de la résolution DNS (Port 53) et de la synchronisation NTP (Port 123).
- Gestion interne : Autorisation d'accès spécifique à la base de données (Host_DB_SRV sur le port 3306) pour l'administration.
- Forçage du Proxy Explicite : Le trafic Web direct (ports 80/443) n'est pas autorisé. À la place, les flux sont obligatoirement dirigés vers le port 3128 du pare-feu, forçant l'utilisation du proxy Squid (Allow LAN to Squid Proxy 3128).
- Routage inter-sites : Autorisation du trafic vers le réseau de gestion partenaire (partner_mgmt_net) via le tunnel VPN.

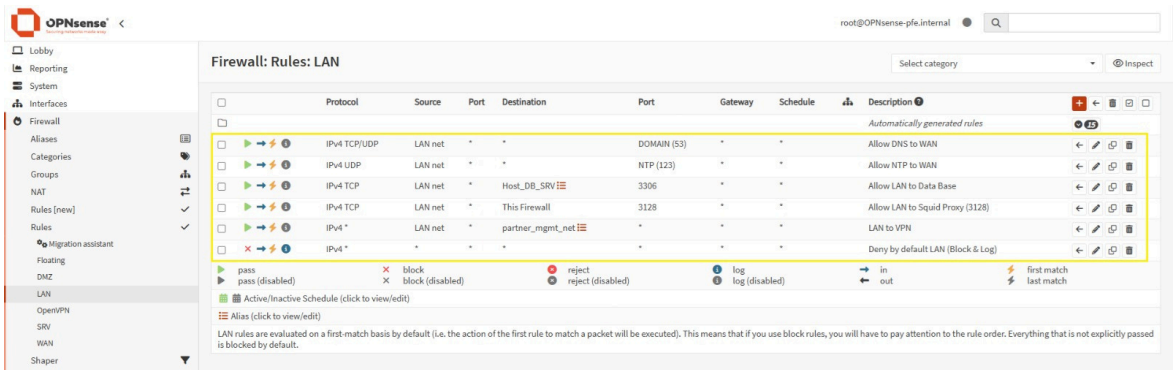


Figure 35 : Règles de l'interface d'administration (LAN/MGMT) illustrant le forçage du proxy explicite et le routage VPN.

C. Zone Démilitarisée (Interface DMZ) :

La DMZ est la zone la plus exposée du réseau interne, hébergeant le serveur Web frontal. L'approche "Zero Trust" y est appliquée de manière absolue : Une seule règle explicite est présente, autorisant le serveur Web (Host_Web_DMZ) à communiquer uniquement avec le serveur de base de données (Host_DB_SRV) et exclusivement via le port SQL (3306). Toute autre communication (ping, SSH, ou tentative de rebond vers d'autres réseaux) est bloquée par la règle implicite finale. Ainsi, en cas de compromission du serveur Web, la menace reste confinée au sein de la DMZ (Containment).

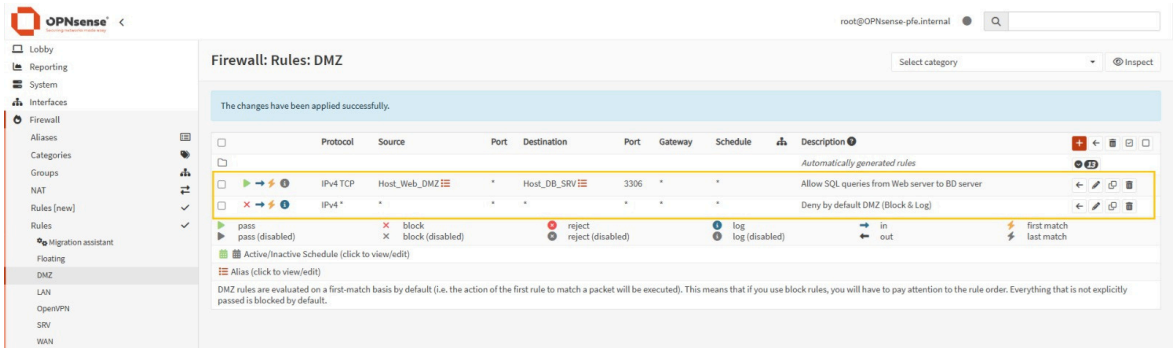


Figure 36 : Règles de l'interface DMZ appliquant une micro-segmentation stricte vers la base de données.

D. Zone des Serveurs Critiques (Interface SRV) :

L'interface SRV héberge la base de données (Backend). Son rôle étant purement passif (elle répond aux requêtes mais n'en initie jamais vers l'extérieur), sa matrice de flux est réduite à son strict minimum. La liste des règles ne contient qu'une seule directive : un blocage total (Deny by default SRV). Grâce à la nature Stateful du pare-feu OPNsense, le trafic de réponse aux requêtes SQL initiées légitimement par la DMZ ou le réseau MGMT est automatiquement autorisé. Cette configuration empêche toute tentative d'exfiltration de données ou de connexion inversée (Reverse Shell) depuis le serveur de base de données.

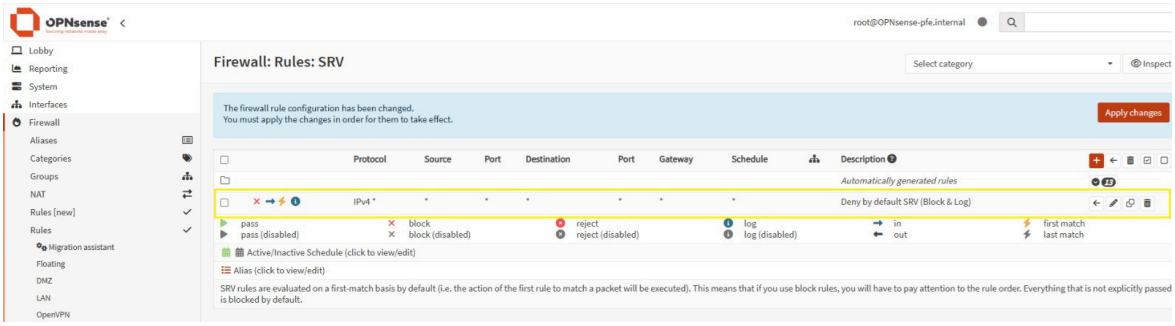


Figure 37 : Interface SRV verrouillée par défaut, reposant sur l'inspection d'état (Stateful Firewall).

E. Interface Tunnel (OpenVPN) :

Cette interface filtre le trafic provenant du tunnel VPN (initié par le Site Principal). Contrairement à une simple autorisation globale, l'accès accordé à l'administrateur distant (partner_mgmt_net) est finement découpé :

- Accès aux services : Autorisation d'accès spécifique au port de la base de données (3306) dans la zone SRV, et aux ports Web (Ports_Web) dans la zone DMZ.
- Accès d'administration : Autorisation d'accès SSH (port 22) vers les zones DMZ et SRV.

- Diagnostic et Gestion : Autorisation des requêtes ICMP (Ping) et de l'accès au portail graphique du pare-feu lui-même (This Firewall), ainsi qu'à la zone d'administration locale (Net_LAN). Une règle de blocage clôture cette interface, assurant qu'aucun privilège non documenté ne puisse transiter par le tunnel.

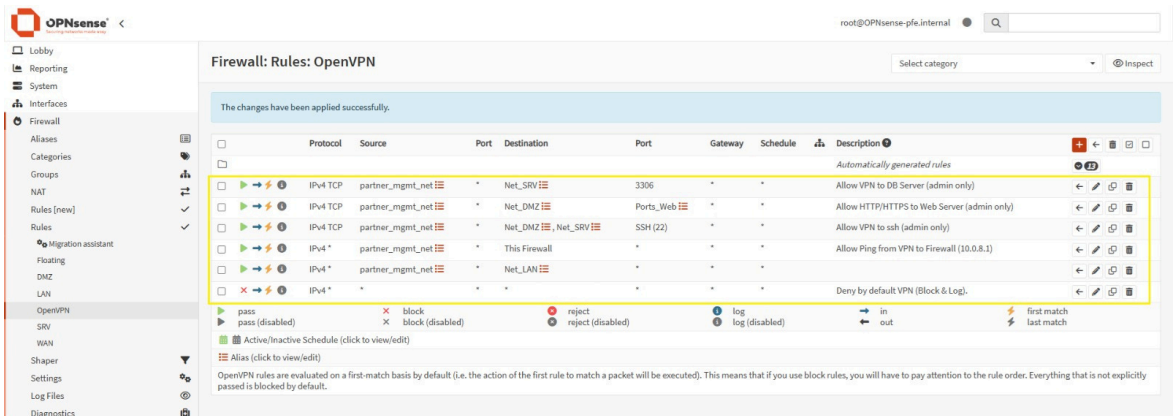


Figure 38 : Règles de l'interface OpenVPN appliquant
un contrôle d'accès granulaire (RBAC) pour l'administration distante.

6. Contrôle et Filtrage du Trafic Web (Squid Proxy) :

La gestion des accès Internet des utilisateurs est une composante critique de la politique de sécurité globale. Afin de surveiller, contrôler et filtrer le trafic Web (HTTP et HTTPS), le service de serveur mandataire (Proxy) basé sur Squid a été déployé. L'architecture s'adapte aux besoins spécifiques de chaque zone : une approche transparente pour le réseau des utilisateurs (Site Principal) et une approche explicite pour le réseau d'administration distant.

6.1. Implémentation du Proxy Transparent (Site Principal) :

Sur le Site Principal hébergeant les utilisateurs standards (LAN), la stratégie du "Proxy Transparent" a été privilégiée. L'avantage majeur de cette architecture réside dans son invisibilité technique : le trafic est filtré à la volée sans nécessiter la moindre configuration manuelle (proxy settings) sur les navigateurs des postes clients.

A. Activation du Service :

Le moteur Squid a été activé globalement depuis l'interface d'administration d'OPNsense, constituant la première étape de la mise en place du filtrage applicatif.

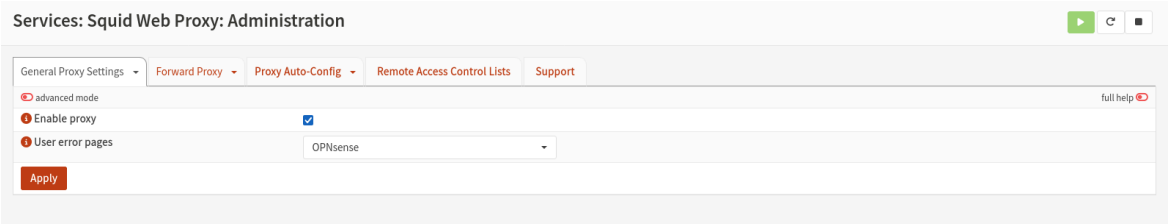


Figure 39 : Activation globale du service Squid Web Proxy sur le pare-feu.

B. Interception et Redirection (NAT Port Forwarding) :

Pour que le pare-feu agisse de manière transparente, il doit intercepter le trafic Web sortant avant qu'il n'atteigne Internet. Cette interception est réalisée via des règles de traduction d'adresses réseau (Destination NAT). La configuration mise en place capture tout le trafic TCP provenant du réseau LAN à destination des ports standards du Web (Port 80 pour HTTP et Port 443 pour HTTPS). Ce trafic est alors détourné et réinjecté de force vers les ports d'écoute internes du proxy Squid (Port 3128 pour le trafic non chiffré et Port 3129 pour le trafic chiffré), le tout à l'insu de l'utilisateur final.

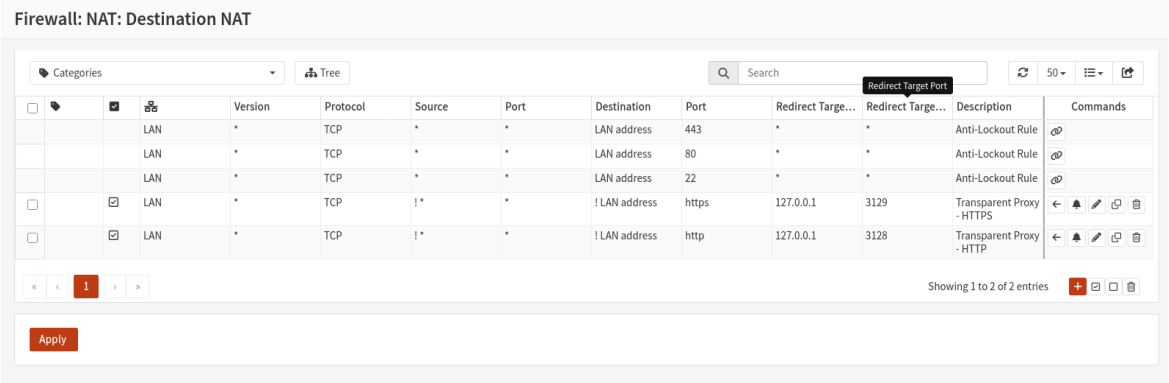


Figure 40 : Règles de redirection NAT (Port Forwarding) interceptant les flux 80/443 vers le proxy.

C. Inspection SSL (Man-in-the-Middle) et Certificats :

La majorité du trafic Web actuel étant chiffrée (HTTPS), le proxy nécessite un mécanisme pour inspecter ce contenu afin d'y appliquer les politiques de filtrage. La technique d'inspection SSL (SSL Bumping) a été implémentée. À cet effet, une Autorité de Certification (CA) interne spécifique, nommée OPNsense-webca, a été générée. Le pare-feu utilise cette CA pour forger dynamiquement des certificats à la volée pour les sites visités. Il déchiffre le trafic, l'analyse, puis le rechiffre vers le client. (Note : Dans un déploiement réel, le certificat public de cette CA doit être déployé sur l'ensemble des postes clients via une GPO pour éviter les alertes de sécurité dans les navigateurs).

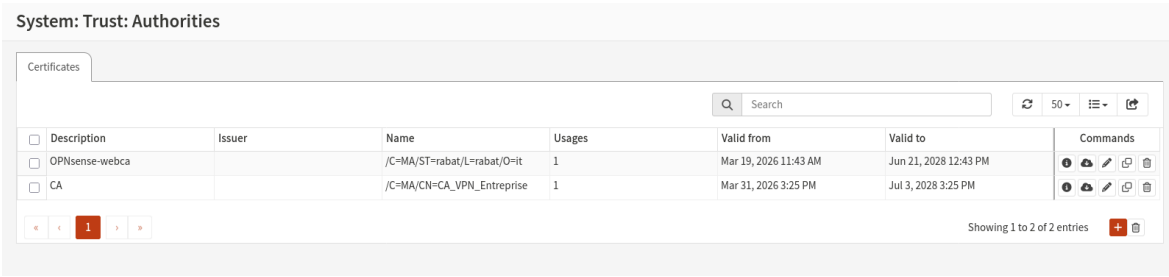


Figure 41 : Création de l'Autorité de Certification (OPNsense-webca) dédiée à l'inspection SSL du trafic HTTPS.

D. Stratégie de Filtrage de Contenu (Blacklists) :

Une fois le trafic intercepté et déchiffré, le moteur de filtrage s'appuie sur des listes de contrôle d'accès (ACL) dynamiques pour autoriser ou bloquer les requêtes. La base de données de filtrage "UT1" (maintenue par l'Université Toulouse 1 Capitole) a été intégrée via l'interface des listes distantes (Remote Access Control Lists). Cette intégration permet au pare-feu de télécharger régulièrement une catégorisation exhaustive des sites Web (malwares, réseaux sociaux, contenu inapproprié, etc.) et d'appliquer automatiquement les restrictions définies par la politique de l'entreprise.

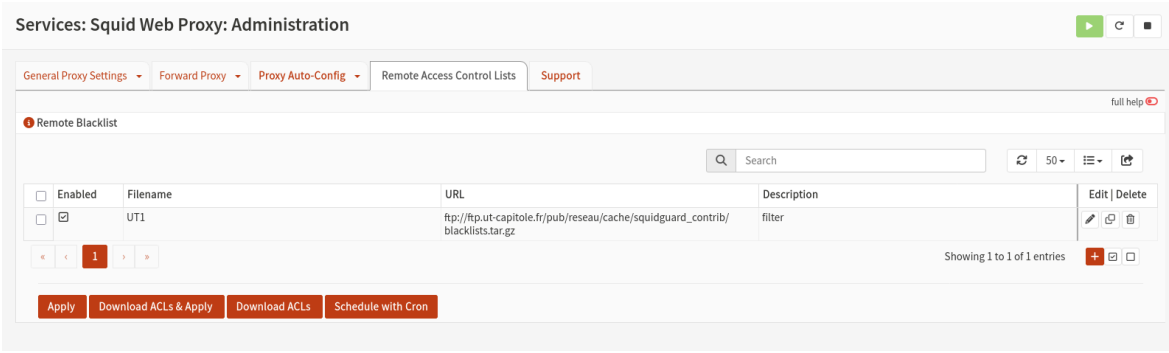


Figure 42 : Intégration de la base de données de filtrage dynamique (Blacklist UT1).

6.2. Implémentation du Proxy Explicite (Site Distant) :

Sur le Site Distant, la gestion de l'accès Internet pour le réseau d'administration (MGMT) repose sur une architecture de "Proxy Explicite" (ou proxy traditionnel).

A. Différence Architecturale :

Conscience du Client La distinction fondamentale entre un proxy transparent et un proxy explicite réside dans le comportement du poste client. Alors que le proxy transparent intercepte silencieusement le flux au niveau du réseau (via des règles NAT) à l'insu de l'utilisateur, le proxy explicite requiert que le client "sache" qu'il utilise un relais. Le système d'exploitation ou le navigateur web doit être expressément paramétré pour ne plus envoyer ses requêtes directement vers Internet, mais vers l'adresse IP locale du pare-feu.

B. Configuration des Postes Clients :

Pour implémenter cette stratégie, les paramètres réseau des machines clientes ont été modifiés. Comme l'illustre la configuration d'un poste de travail Windows 10 de la zone d'administration, le système est configuré pour relayer l'intégralité de son trafic Web vers l'adresse IP de l'interface MGMT du pare-feu distant (192.168.89.3) via le port d'écoute standard de Squid (3128).
Il est important de rappeler (comme détaillé dans la section 4.5.2) que cette configuration n'est pas facultative : les règles du pare-feu bloquent strictement les requêtes Web directes (ports 80 et 443) sortant de ce réseau. Si l'utilisateur tente de désactiver ce paramètre proxy dans son système, son accès à Internet est immédiatement coupé.

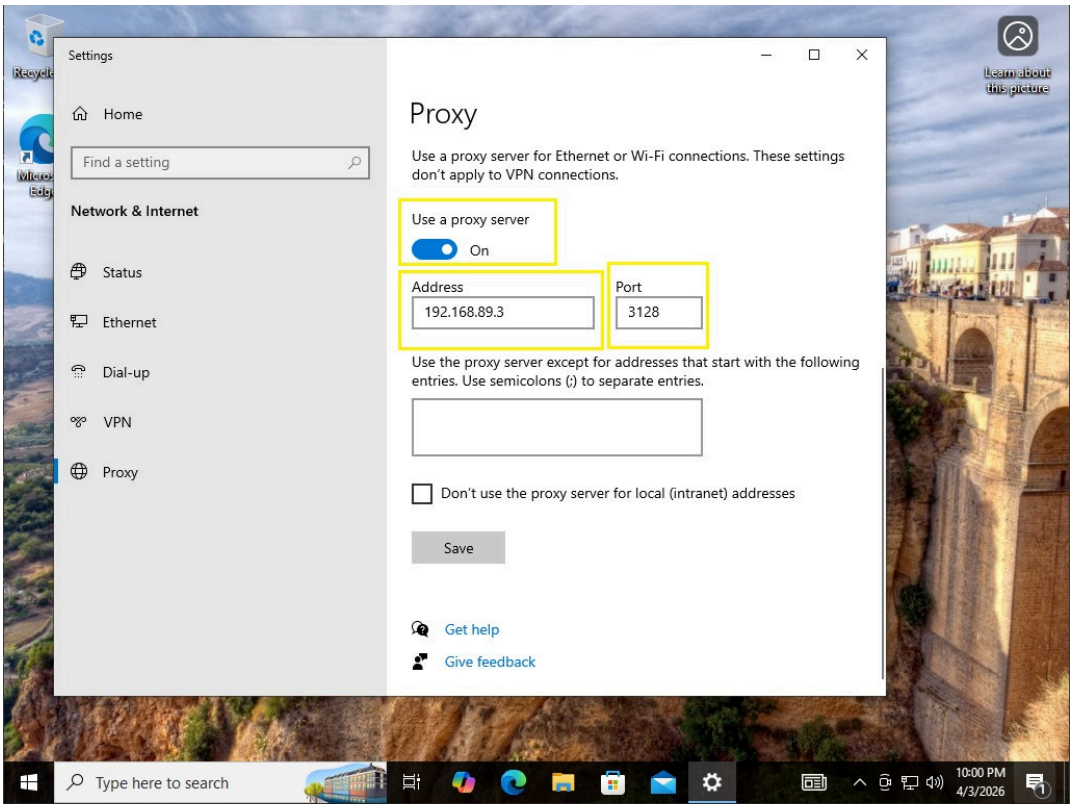


Figure 43 : Configuration manuelle d'un poste client (Windows 10) forçant l'utilisation du proxy explicite.

C. Mutualisation du Moteur de Filtrage :

Afin d'éviter toute redondance opérationnelle et de maintenir une politique de sécurité homogène sur l'ensemble de l'infrastructure, le cœur du service Squid sur ce site distant a été configuré de manière identique au Site Principal. Les mécanismes d'activation du service, l'inspection cryptographique du trafic chiffré (SSL Bumping via une Autorité de Certification locale) ainsi que la synchronisation des listes de filtrage de contenu (Blacklists UT1) partagent exactement la même architecture technique que celle décrite à la section précédente.

7. Déploiement du Système de Détection et Prévention d'Intrusion (Suricata IDS/IPS) :

Pour compléter la politique de filtrage statique (Pare-feu) et la protection applicative (Proxy), une couche de sécurité dynamique a été intégrée via le déploiement d'un système de détection et de prévention d'intrusion (IDS/IPS). Le moteur open-source Suricata a été sélectionné pour sa capacité à analyser le trafic en temps réel à très haut débit.

7.1. Configuration du Moteur (Mode IPS) :

Afin de ne pas se limiter à une simple journalisation des attaques (mode IDS), le service a été configuré en mode prévention (IPS - Intrusion Prevention System) pour bloquer activement les menaces. L'activation s'appuie sur le framework Netmap, qui permet au moteur Suricata d'intercepter les paquets au niveau de l'interface réseau avant même qu'ils ne soient traités par le système d'exploitation. Le service a été activé en mode "Promiscuous" sur l'interface ciblée (LAN). Pour garantir des performances optimales et réduire la latence induite par l'inspection profonde des paquets (DPI), l'algorithme de correspondance de motifs (Pattern matcher) Hyperscan a été sélectionné.

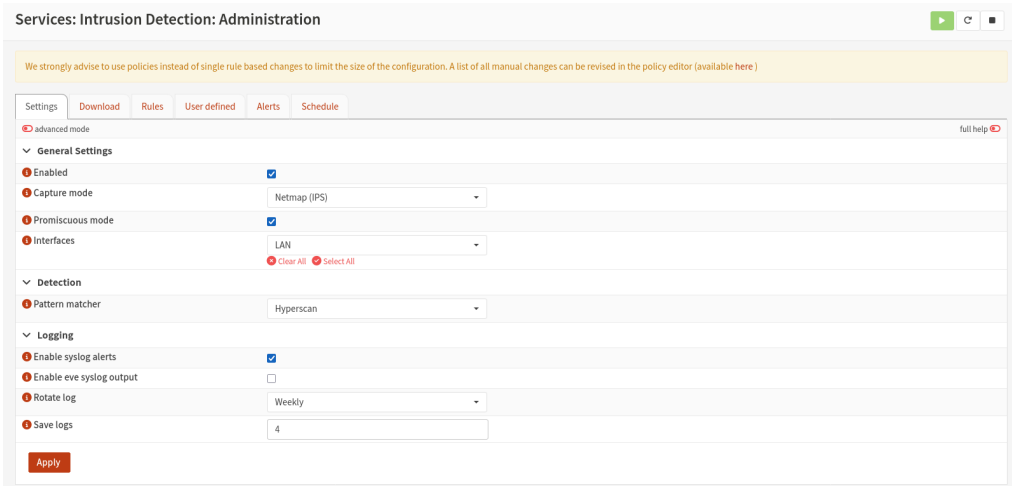


Figure 44 : Activation du moteur Suricata en mode IPS (Netmap) avec accélération Hyperscan.

7.2. Intégration des Signatures de Menaces (Emerging Threats Telemetry) :

L'efficacité d'un moteur IPS repose intégralement sur la qualité et l'actualisation de ses bases de signatures (Rulesets). Pour garantir une protection contre les attaques "Zero-Day" et les menaces contemporaines, l'infrastructure a été connectée aux bases de données "Emerging Threats" (ET).
Plus spécifiquement, le programme ET Telemetry a été configuré. Ce modèle de distribution repose sur un accord de partenariat technique entre le pare-feu et le fournisseur (Proofpoint) : en l'échange d'un jeton cryptographique (Token) autorisant le téléchargement gratuit des règles de niveau

entreprise (Enterprise-grade rules), le système s'engage à partager ses journaux d'événements et ses données de télémétrie de manière anonymisée. Cette approche collaborative permet de bénéficier d'une base de signatures de très haute qualité tout en participant à l'effort global de détection des menaces (Threat Intelligence).

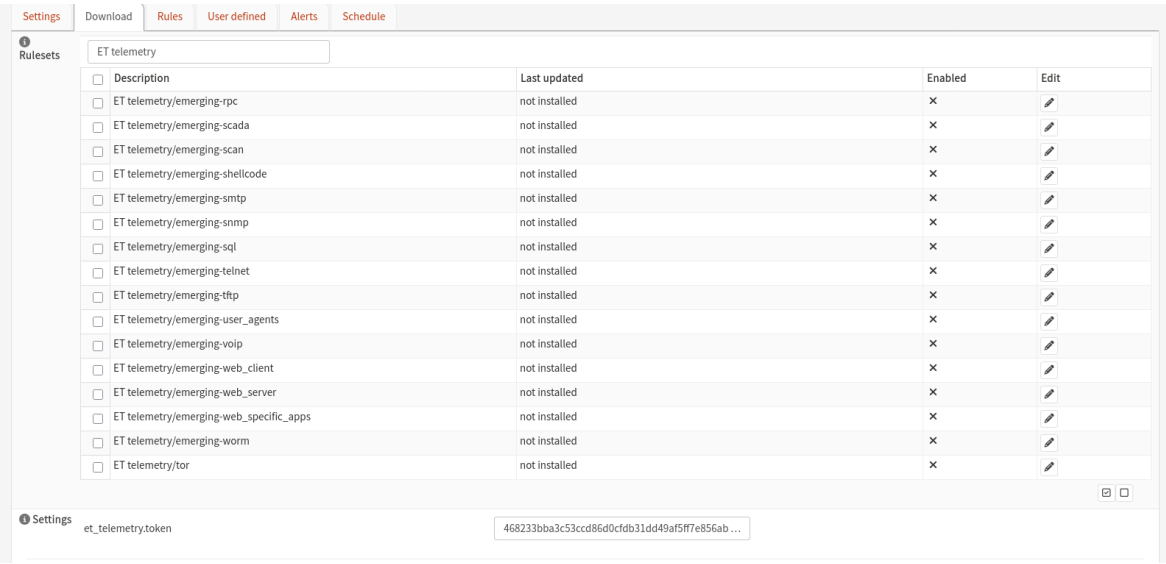


Figure 45: Configuration du jeton (Token) pour l'intégration continue des règles ET Telemetry.

7.3. Création et Application de Règles Personnalisées (Custom Rules) :

Bien que les bases de données communautaires couvrent la majorité des cybermenaces, des règles spécifiques ont été créées manuellement pour répondre aux exigences précises de l'architecture et interdire les comportements de reconnaissance.

Un fichier de règles personnalisé (customnmap.rules) a été rédigé et intégré au moteur Suricata. Comme l'illustre la configuration, ces signatures ciblent explicitement les outils d'audit offensifs. Deux règles principales ont été définies pour détecter les balayages de ports à haute fréquence (High Rate Port Scan) ainsi que l'utilisation du moteur de scripts de l'outil Nmap (Nmap Scripting Engine - NSE). Puisque le moteur opère en mode IPS, l'action associée à ces signatures a été strictement définie sur "drop" (rejeter). Ainsi, toute tentative de cartographie ou de scan de vulnérabilités initiée par un attaquant ou un poste compromis sera instantanément bloquée et détruite au niveau de la couche réseau.

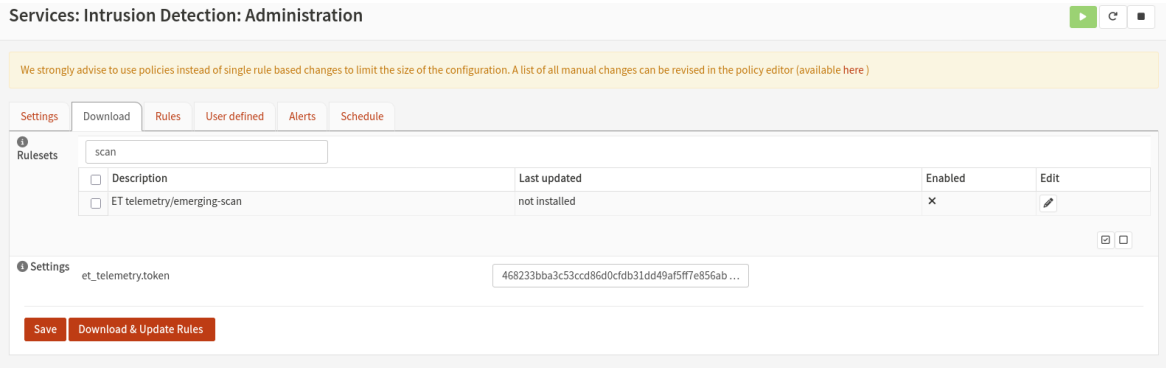


Figure 46 : Application de règles manuelles (Custom Rules) configurées pour bloquer (Drop) les tentatives de reconnaissance Nmap.

8. Conclusion :

En conclusion, ce chapitre a permis de concrétiser l'architecture théorique du projet en une infrastructure réseau globale, fonctionnelle et hautement sécurisée. À travers le déploiement et la configuration des pare-feux OPNsense sur les deux sites, l'ensemble des exigences techniques a été implémenté avec succès. De la gestion de la haute disponibilité (Multi-WAN) à l'établissement du tunnel crypté OpenVPN, chaque étape a été guidée par l'application rigoureuse du principe "Zero Trust" et de la micro-segmentation. Enfin, l'intégration des couches d'inspection applicative, avec le filtrage Web (Squid Proxy) et le moteur de prévention d'intrusion (Suricata IPS), a achevé de consolider cette stratégie de défense en profondeur.

Toutefois, une architecture de cette envergure ne peut être considérée comme aboutie sans une vérification minutieuse de son comportement en conditions réelles. L'infrastructure étant désormais déployée, il est impératif d'éprouver sa résilience et sa conformité face au cahier des charges initial. C'est précisément l'objet du chapitre suivant, le Chapitre 5 : Tests et Validations, qui s'attachera à démontrer l'efficacité opérationnelle de ces mécanismes de sécurité à travers une série de scénarios pratiques, de simulations d'accès et d'analyses de journaux d'événements (logs).

Chapitre 5 :
Tests et Validations

1. Intoduction :

L'objectif de ce chapitre est de valider l'efficacité et la robustesse de l'architecture réseau en conditions réelles. Après avoir confirmé les capacités de supervision du système, une série de tests pratiques est menée sur chaque composant critique (Multi-WAN, VPN, segmentation "Zero Trust", filtrage Proxy et IDS/IPS). L'analyse des résultats et des journaux d'événements (logs) permettra de certifier que l'infrastructure répond strictement aux exigences de sécurité et de résilience définies lors de la conception.

2. Supervision Globale et Analyse du Trafic :

Une architecture de sécurité, même parfaitement configurée, nécessite une surveillance continue pour garantir son intégrité et optimiser ses performances. Le système OPNsense intègre des outils avancés de télémétrie et de reporting qui ont été validés lors de cette phase de test.

2.1. Le Tableau de Bord Centralisé (Dashboard) :

Le tableau de bord principal (Lobby) sert de centre de contrôle global. Comme l'illustre la capture d'écran, cette interface offre une visibilité en temps réel sur la santé matérielle du pare-feu (utilisation du CPU, de la mémoire, et du disque). Elle permet également de monitorer instantanément l'état des interfaces réseau, le statut des passerelles (Gateways), et l'exécution correcte des services critiques tels que le Proxy Squid, le VPN, et le moteur de détection d'intrusion. De plus, le widget de télémétrie confirme la connexion active avec les serveurs Proofpoint (Emerging Threats).

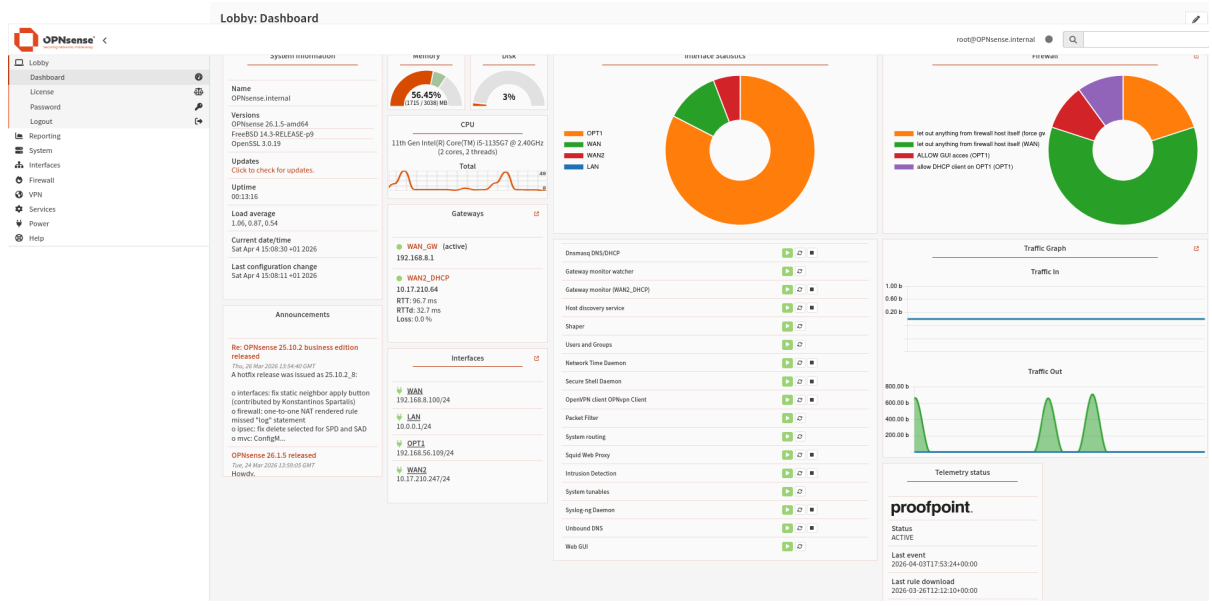


Figure 47: Tableau de bord centralisé affichant l'état des ressources, des interfaces et des services critiques.

2.2. Analyse Visuelle et Granulaire du Trafic :

Au-delà de la supervision globale, le système permet une inspection approfondie des flux traversant l'infrastructure via le module de reporting de trafic. L'affichage sous forme de graphiques (Graph) offre une représentation visuelle dynamique de la bande passante consommée sur chaque interface (LAN, WAN, OPT1). Cette vue permet aux administrateurs d'identifier immédiatement les pics d'activité anormaux ou les congestions réseau.

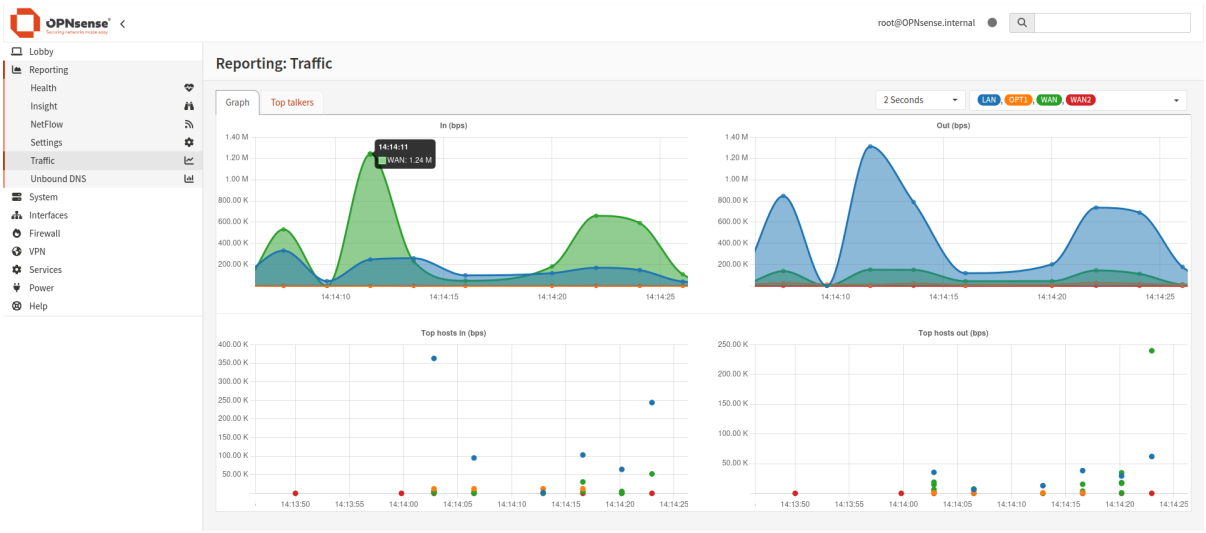


Figure 48 : Suivi graphique en temps réel des flux entrants et sortants sur les différentes interfaces.

En complément, l'onglet des hôtes les plus actifs (« Top Talkers ») fournit une granularité absolue. Le système liste les adresses IP exactes (internes et externes) responsables de la consommation de bande passante, accompagnées des débits précis. Cet outil s'avère indispensable pour l'investigation numérique (Forensics), la détection d'exfiltration de données, ou le simple ajustement des règles de qualité de service (QoS).

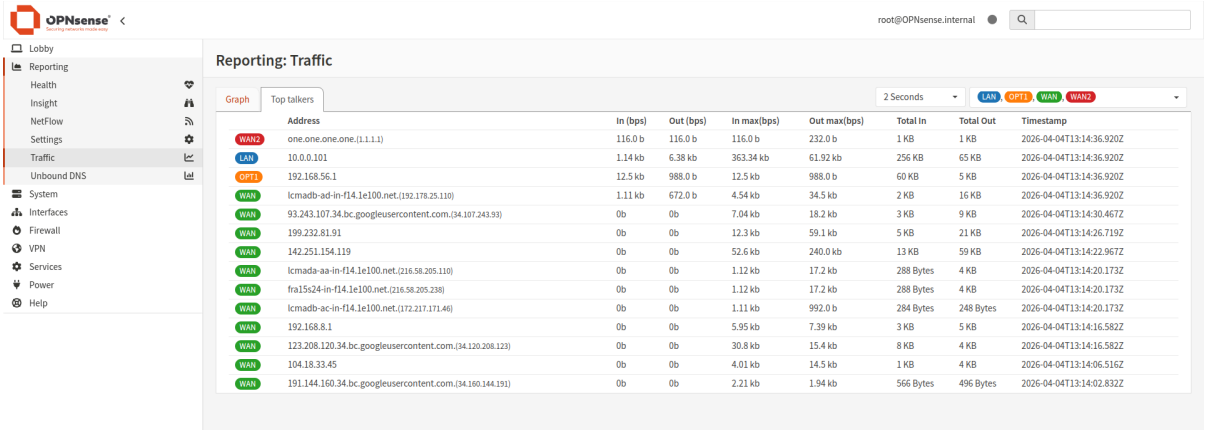


Figure 49 : Analyse granulaire des connexions ("Top talkers") identifiant les sources exactes du trafic réseau.

3. Validation du Routage et de la Haute Disponibilité (Multi-WAN) :

Cette section est consacrée à la vérification des mécanismes de gestion du trafic réseau sur le Site Principal, incluant le contrôle de la bande passante et la redondance des liens Internet.

3.1. Test de la Qualité de Service (QoS) :

Le premier test vise à valider l'application de la politique de limitation de bande passante (Traffic Shaping) sur le réseau des utilisateurs (LAN). Pour rappel, une limite stricte de 5 Mbps avait été configurée pour le téléchargement et le téléversement. Un test de débit réel a été exécuté depuis une machine cliente (Lubuntu) située dans la zone LAN. Les résultats obtenus via l'outil de mesure affichent une vitesse de connexion plafonnée à 4,7 Mbps. Ce résultat, très légèrement inférieur au seuil théorique de 5 Mbps (différence justifiée par l'encapsulation des paquets réseau - overhead), prouve que le bridage est pleinement effectif. Il est ainsi garanti qu'aucun poste client ne pourra monopoliser les ressources de la liaison globale de l'entreprise.



Figure 50 : Mesure du débit depuis un poste client confirmant le bridage à ~5 Mbps.

3.2. Test de Tolérance de Panne (Failover) :

Ce test a pour but de vérifier la résilience de la connectivité Internet en cas de défaillance matérielle ou logique de la ligne principale (mode Actif/Passif). Une dégradation de la liaison primaire a été simulée. L'interface de supervision des passerelles (Gateways) démontre que le système a immédiatement détecté une anomalie (perte de paquets critique de 25%) sur la ligne principale (WAN_GW), entraînant son passage à l'état inactif (statut rouge). Conformément à la configuration du groupe de basculement, le moteur de routage a automatiquement basculé les flux vers la passerelle de secours (WAN2_Getway), qui est restée opérationnelle (statut vert). La continuité de service a été assurée sans aucune intervention administrative manuelle.

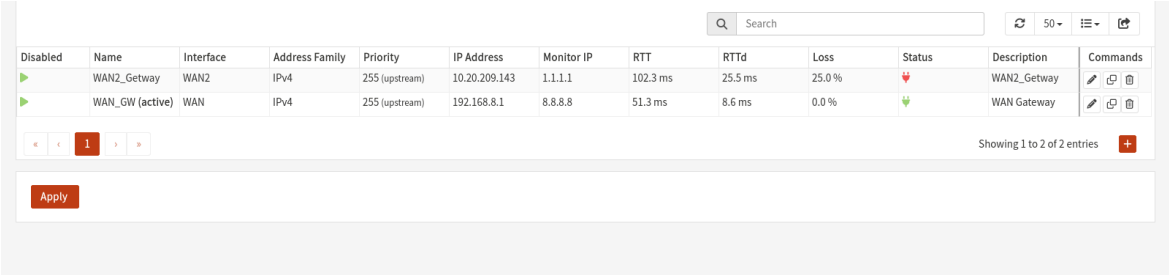


Figure 51 : Supervision des passerelles illustrant la détection de panne sur le lien primaire et le maintien du lien secondaire.

3.3. Test de Répartition de Charge (Load Balancing) :

La validation du mode Actif/Actif (Load Balancing) consiste à s'assurer que l'infrastructure est capable d'exploiter plusieurs liaisons simultanément pour agréger la capacité réseau. L'analyse des statuts confirme que, dans des conditions normales, les deux interfaces (WAN_GW et WAN2_Getway) sont parfaitement fonctionnelles (statut vert) sans aucune perte de paquets. De plus, la supervision du groupe de passerelles nommé "LoadBalancing" atteste que les deux liaisons opèrent conjointement sur le même niveau de priorité (Tier 1) et sont reconnues comme "Online". Le pare-feu distribue donc avec succès les nouvelles sessions sortantes de manière équilibrée sur les deux accès Internet.

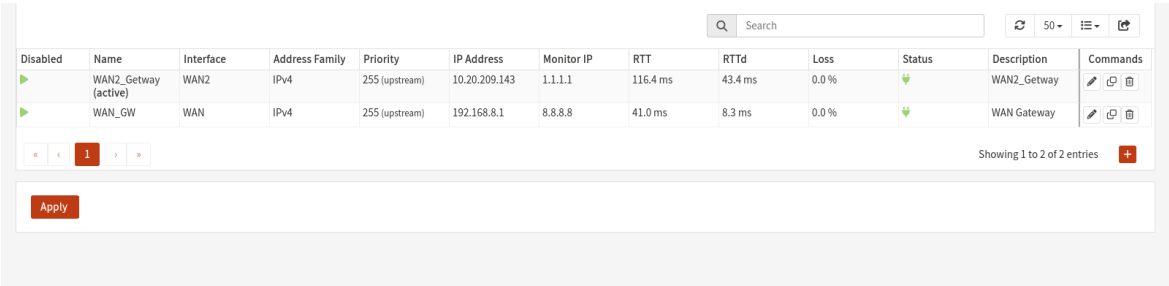


Figure 52 : Statut des passerelles démontrant l'opérabilité simultanée des deux accès Internet.

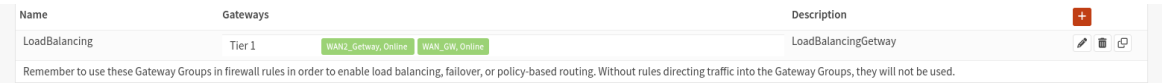


Figure 53 : Validation du groupe de passerelles en mode Actif/Actif (Tier 1 pour les deux interfaces).

4. Validation du Tunnel VPN Site-à-Site :

L'établissement d'une communication sécurisée entre les deux sites repose intégralement sur le tunnel OpenVPN. La validation de cette architecture de confiance nécessite de confirmer la réussite de la négociation cryptographique et l'état opérationnel des deux instances (Serveur et Client).

4.1. État de l'instance Serveur (Site Distant) :

Sur le Site Distant, le statut de l'instance OpenVPN configurée en mode "Serveur" a été inspecté via le module de supervision des connexions (Connection Status). L'interface affiche un statut global « OK ». Ce résultat confirme que le service VPN a démarré avec succès, qu'il a chargé la clé privée et le certificat de l'Autorité de Certification (CA), et qu'il maintient le tunnel ouvert pour le routage des flux sécurisés.

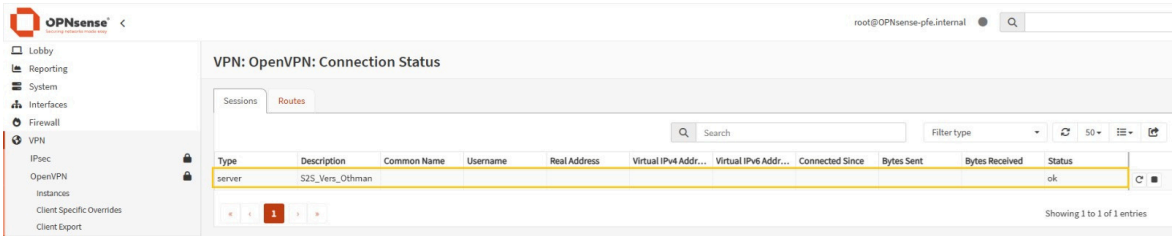


Figure 54 : Supervision du Site Distant confirmant le statut opérationnel (OK) de l'instance Serveur OpenVPN.

4.2. État de l'instance Client (Site Principal) :

Sur le Site Principal, l'instance agissant en tant que "Client" a également été vérifiée. Le tableau de bord indique explicitement un statut « connected » (connecté), prouvant que le processus d'authentification mutuelle par certificats (PKI) a abouti sans erreur. L'analyse détaillée révèle également qu'une adresse IP virtuelle (Virtual IPv4 Address : 10.0.8.2) a été attribuée avec succès par le serveur au client au sein du réseau d'interconnexion (Overlay Network). La présence de compteurs de données (Bytes Sent / Bytes Received) atteste de la bonne encapsulation et du transfert effectif des paquets chiffrés de bout en bout.

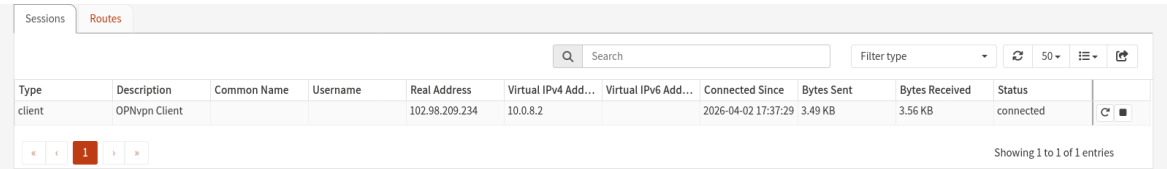


Figure 55 : Supervision du Site Principal validant la connexion active du Client VPN et l'attribution de l'IP virtuelle.

5. Validation de la Politique de Sécurité "Zero Trust" :

Cette section est fondamentale car elle valide le cœur sécuritaire de l'infrastructure : la micro-segmentation et le cloisonnement des réseaux. L'objectif est de démontrer que les règles de pare-feu appliquent strictement le principe du moindre privilège, en fonction de la zone d'origine du trafic.

5.1. Validation des privilèges d'administration inter-sites :

Le premier scénario de test simule les actions d'un administrateur situé sur le réseau de gestion du Site Principal (interface OPT1 / MGMT). La machine d'audit (Kali Linux) s'est vu attribuer une adresse IP valide dans ce sous-réseau (192.168.56.111). Conformément à la politique de sécurité établie, cet administrateur doit bénéficier d'un accès complet à l'infrastructure du partenaire via le tunnel VPN. Une série de tests ICMP (Ping) a été exécutée vers les réseaux cibles : le réseau d'administration distant (192.168.89.3), la zone DMZ (192.168.228.4) et la zone des serveurs critiques SRV (192.168.130.4). Les résultats confirment une réussite totale (0% de perte de paquets). Les règles de pare-feu liées à l'interface VPN autorisent donc correctement l'acheminement de ce trafic privilégié.

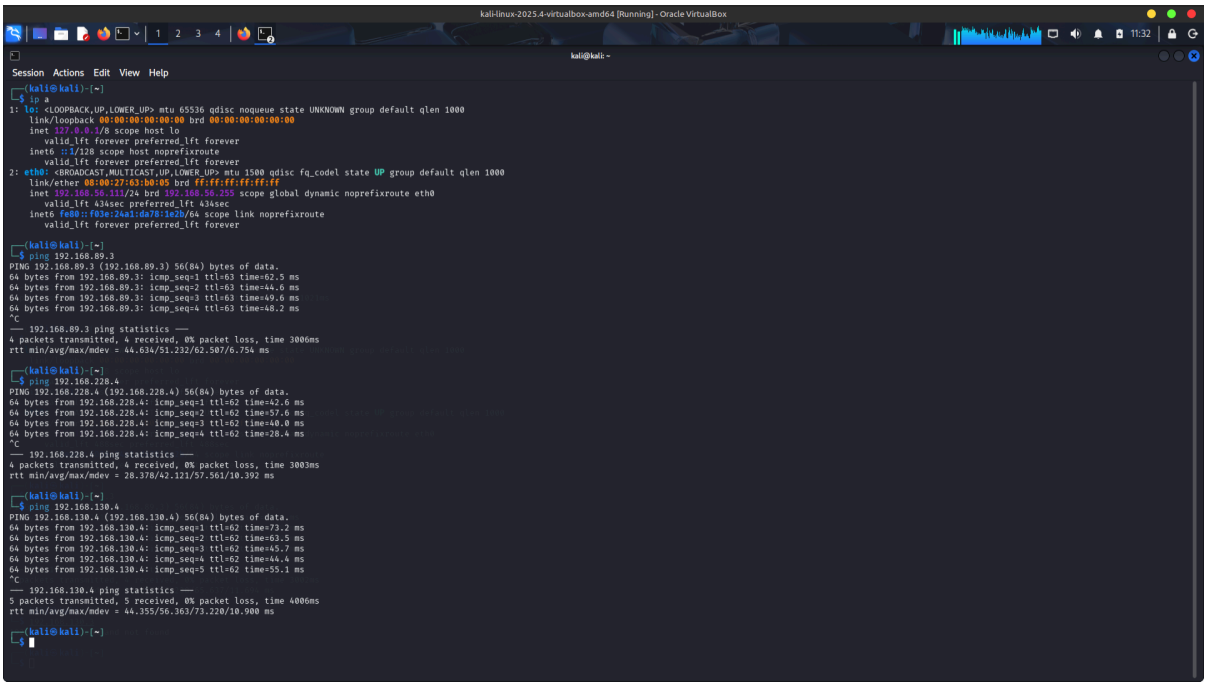


Figure 56 : Validation des accès réseau étendus (Ping réussis) depuis le poste d'un administrateur du Site Principal vers l'ensemble des zones du Site Distant.

Afin de confirmer ces privilèges d'administration au niveau applicatif, une tentative de connexion à l'interface de gestion (Web GUI) du pare-feu distant a été effectuée depuis ce même poste administrateur. Comme le démontre la capture d'écran, l'administrateur est capable d'ouvrir simultanément et de manière sécurisée les tableaux de bord des deux pare-feux (Local et Distant).

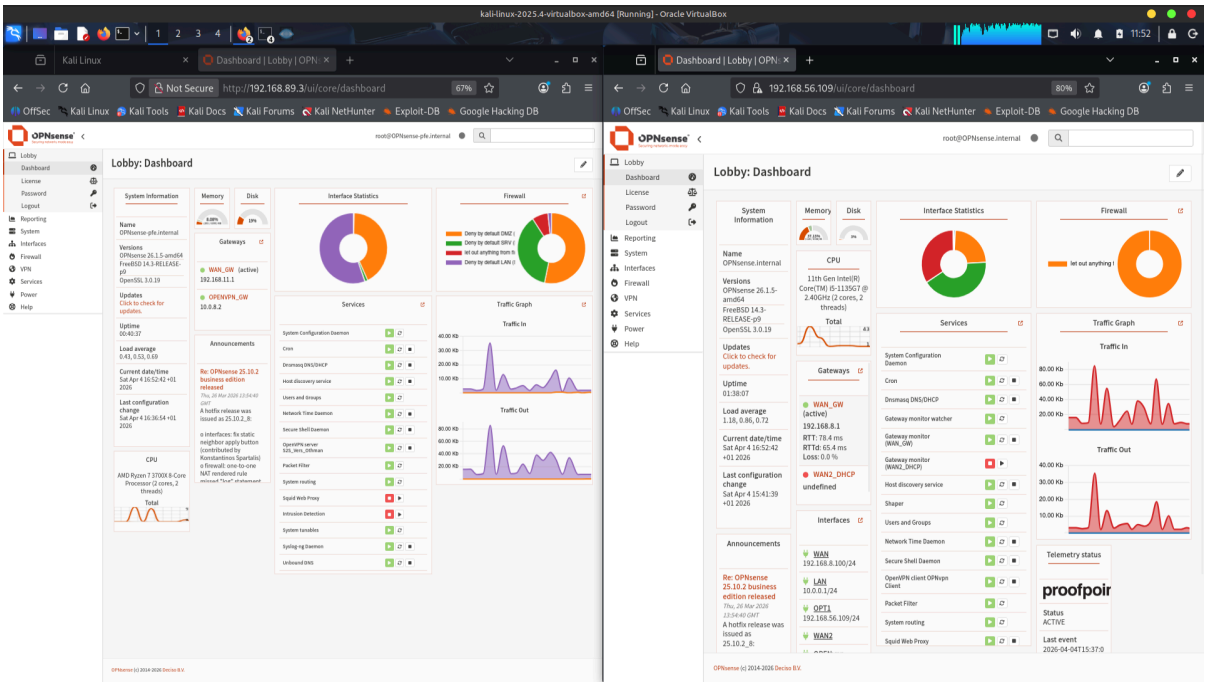


Figure 57 : Démonstration de l'accès croisé aux interfaces d'administration (GUI) locale et distante, validant les privilèges étendus.

5.2. Validation de l'isolation du réseau utilisateurs (LAN) :

Le second scénario, crucial pour l'approche Zero Trust, vise à prouver que le réseau des utilisateurs standards (LAN) est hermétiquement isolé de l'infrastructure partenaire. Depuis une machine cliente (Lubuntu) possédant une adresse IP de la zone LAN (10.0.0.101), la même série de tests ICMP a été lancée vers les zones distantes (MGMT, DMZ, SRV). Le résultat est sans appel : une perte totale de paquets (100% packet loss) sur l'ensemble des requêtes. Le trafic est intercepté et détruit par la règle de blocage par défaut (Deny by default) appliquée sur l'interface LAN. Ce test confirme qu'une éventuelle compromission d'un poste utilisateur sur le Site Principal n'aura aucun impact de propagation sur les serveurs ou l'administration du Site Distant.

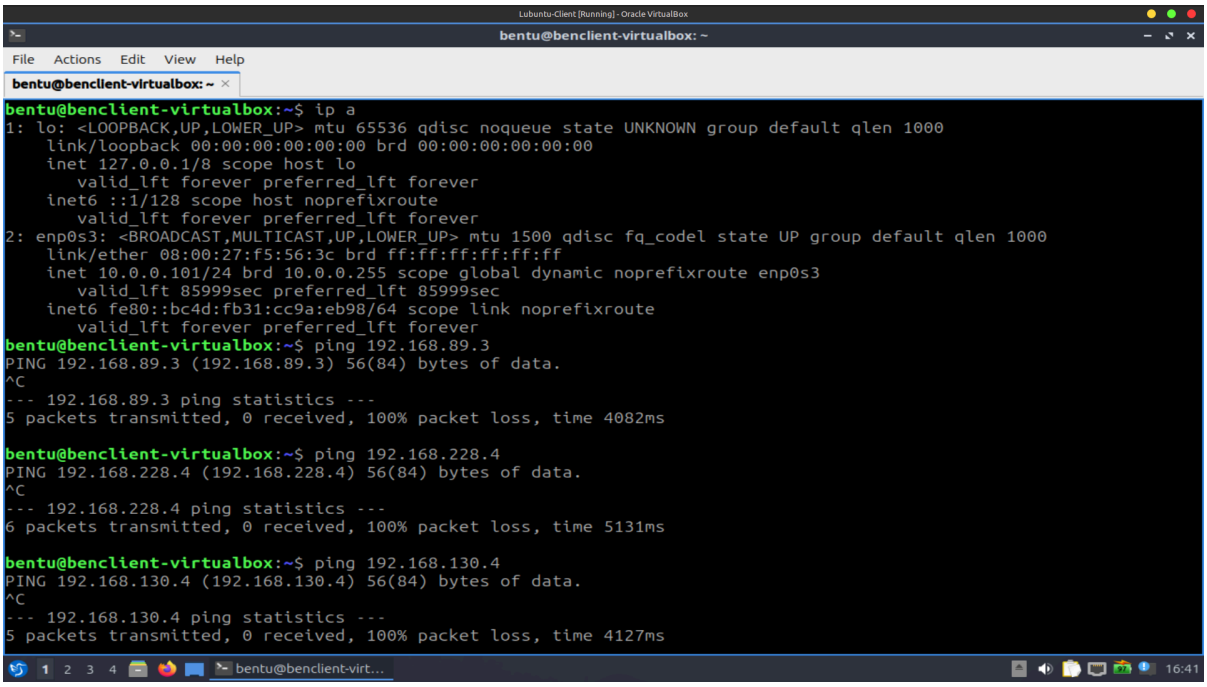


Figure 58 : Validation de l'isolation stricte du réseau LAN (Ping échoués) vers les infrastructures distantes.

6. Validation du Filtrage Web (Squid Proxy) :

Cette section vise à vérifier l'efficacité de l'inspection applicative et du filtrage de contenu mis en place sur les deux sites. L'objectif est de s'assurer que le moteur de filtrage intercepte bien le trafic HTTPS, l'analyse, et applique les restrictions basées sur les listes de contrôle d'accès (Blacklists).

Pour les besoins de ce test, la catégorie liée aux intelligences artificielles (mot-clé "ai") a été préalablement ajoutée aux listes de blocage du pare-feu. Une tentative de navigation vers le domaine https://openai.com/ a ensuite été initiée depuis un poste client (Lubuntu) situé sur le réseau interne.

Le résultat obtenu à l'écran est une page d'erreur "Access Denied" (Accès refusé) générée directement par le service Squid d'OPNsense. Ce comportement valide plusieurs points critiques de l'architecture :

- L'inspection SSL (SSL Bumping) est fonctionnelle : Le pare-feu a été capable d'intercepter et de déchiffrer la requête HTTPS initiale pour lire l'URL demandée.
- Le filtrage par liste noire est opérationnel : Le moteur de règles a correctement identifié le domaine cible comme appartenant à une catégorie interdite et a coupé la connexion.

Afin d'éviter toute redondance dans ce document, il est important de souligner que ce comportement de blocage a été validé avec succès sur les deux infrastructures :

- Sur le Site Principal, le blocage s'est opéré de manière totalement invisible pour le système d'exploitation via le Proxy Transparent (redirection NAT).
- Sur le Site Distant, le blocage s'est opéré suite au transfert de la requête par le navigateur configuré manuellement pour utiliser le Proxy Explicite.

L'application de la politique de restriction Web est donc uniforme et centralisée sur l'ensemble du réseau.

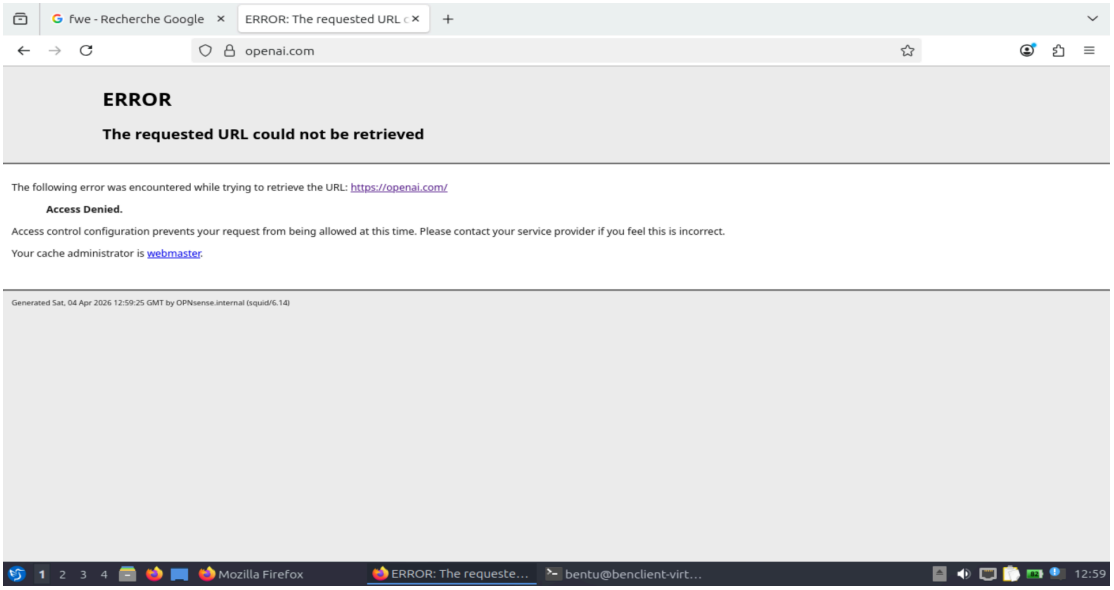


Figure 59 : Interception et blocage effectif d'un domaine non autorisé (openai.com) par le proxy Squid.

7. Validation de la Détection et Prévention d'Intrusion (Suricata) :

La dernière phase de validation est consacrée à l'évaluation du système de prévention d'intrusion (IPS). L'objectif est de s'assurer que le moteur Suricata identifie et neutralise activement les comportements hostiles, tels que les tentatives de reconnaissance et de cartographie du réseau.

7.1 Simulation de l'attaque (Reconnaissance Nmap) :

Afin de tester l'efficacité des signatures de détection, une simulation d'attaque interne a été réalisée. Une analyse de ports agressive (Intense Scan) a été initiée depuis une machine d'audit offensif (Kali Linux, adresse IP 10.0.0.43) ciblant l'interface locale du pare-feu (10.0.0.1). L'outil Nmap a été déployé avec les paramètres -T4 -A -v, ce qui inclut des sondes d'identification de système d'exploitation et l'exécution du moteur de scripts Nmap (NSE).

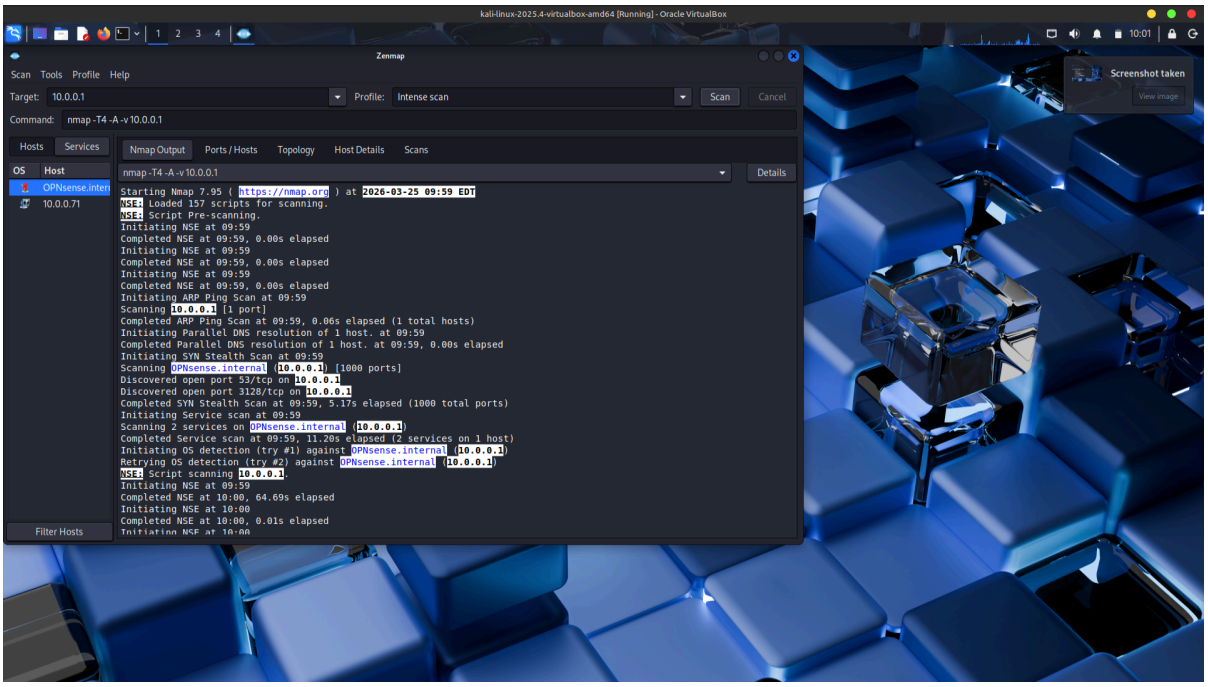


Figure 60 : Exécution d'un scan de reconnaissance agressif (Nmap) depuis une machine d'audit.

Cela prouve que le système ne s'est pas contenté de journaliser l'événement (mode IDS passif), mais a activement détruit les paquets malveillants (mode IPS préventif) au niveau de la couche réseau, protégeant ainsi le pare-feu contre une énumération plus poussée.

7.2. Réponse et Blocage du système (Alertes IPS) :

Du côté de l'infrastructure de défense, l'interface d'administration des alertes Suricata confirme l'interception immédiate de l'attaque. L'analyse des journaux d'événements révèle une série d'alertes déclenchées par la signature « ET SCAN Possible Nmap User-Agent Observed » (SID 2024364), issue de la base de données Emerging Threats. Le moteur d'inspection a correctement identifié que la source (10.0.0.43) tentait d'explorer abusivement le port du proxy (3128). Surtout, la colonne d'action indique explicitement le statut « blocked ».

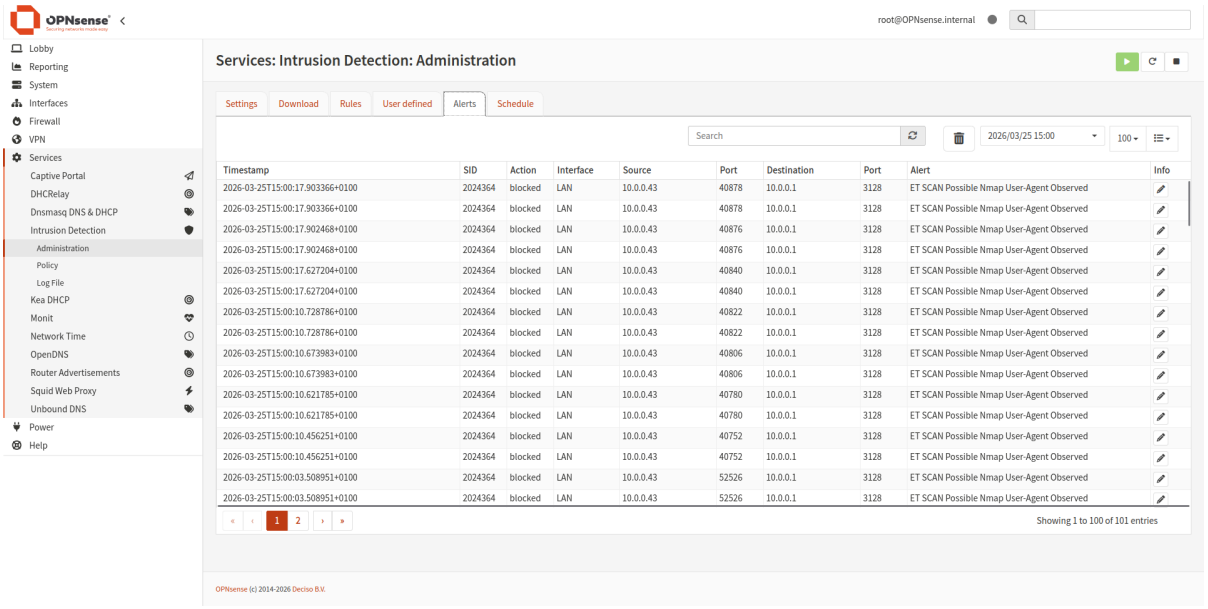


Figure 61 : Tableau de bord des alertes Suricata confirmant l'identification et le blocage proactif de l'attaque Nmap.

8. Conclusion :

En conclusion, l'ensemble des tests menés au cours de ce chapitre a permis de valider de manière irréfutable l'efficacité, la stabilité et la sécurité de l'architecture déployée. La confirmation initiale du fonctionnement des outils de supervision a prouvé que l'infrastructure est parfaitement sous contrôle et auditable en temps réel. Les scénarios pratiques ont ensuite démontré la résilience du routage face aux pannes (Multi-WAN), la fiabilité du chiffrement inter-sites (OpenVPN) et l'étanchéité absolue des zones réseau grâce à l'application stricte de la politique "Zero Trust". Enfin, les simulations d'accès non autorisés et d'attaques réseau ont validé la réactivité instantanée des couches de défense applicatives (Squid Proxy) et de prévention d'intrusion (Suricata). Le cahier des charges technique et sécuritaire est ainsi intégralement respecté, confirmant la mise en œuvre réussie d'une véritable stratégie de défense en profondeur.

Conclusion Générale

L'aboutissement de ce Projet de Fin d'Études a permis de concrétiser un cahier des charges exigeant en une infrastructure réseau opérationnelle et hautement sécurisée. Ce travail démontre la viabilité d'une architecture d'entreprise robuste, fondée sur le paradigme "Zero Trust" et le principe de Défense en Profondeur, pour contrer des cybermenaces croissantes.

La démarche d'ingénierie adoptée a permis de relever chaque défi technique avec rigueur. La continuité de service (Multi-WAN) et la confidentialité des échanges (VPN inter-sites) ont été assurées, tandis que la micro-segmentation a garanti un cloisonnement strict des environnements. L'intégration du filtrage applicatif (Squid) et de la prévention d'intrusion (Suricata IPS) a doté l'infrastructure d'une défense proactive. Enfin, la phase de validation a confirmé, via des simulations d'attaques et de pannes, que l'ensemble des systèmes neutralise efficacement les menaces, validant ainsi la fiabilité globale de la conception.

Puisque la cybersécurité est un domaine en perpétuelle évolution, de fortes ambitions se dessinent pour l'avenir de cette infrastructure. L'objectif est d'approfondir l'expertise technique, tant sur le volet défensif (Blue Team) qu'offensif (Red Team), à travers les perspectives d'amélioration suivantes :

- Déploiement d'un SOC (Blue Team) : Intégrer une solution SIEM (telle que Wazuh) pour centraliser les journaux, corréler les événements en temps réel et orchestrer la réponse aux incidents de manière centralisée.
- Simulations d'attaques avancées (Red Team) : Exécuter des scénarios d'intrusion complexes (APT) afin d'éprouver la résilience des mécanismes de défense et d'identifier d'éventuelles vulnérabilités résiduelles.
- Haute disponibilité matérielle (CARP) : Implémenter un cluster de pare-feux en mode Actif/Passif sur chaque site, éliminant ainsi le pare-feu comme point de défaillance unique (SPOF).
- Contrôle d'accès au réseau (NAC) : Déployer le protocole 802.1X couplé à un serveur RADIUS pour imposer une authentification forte des machines avant l'obtention d'une adresse IP sur le réseau local.

En définitive, ce projet constitue un tremplin technique et professionnel majeur. Il a permis de consolider des compétences pointues en ingénierie réseau et en sécurité des systèmes d'information, tout en préparant le terrain pour l'acquisition continue de nouvelles maîtrises opérationnelles face aux défis cybernétiques de demain.

Bibliographie et Webographie

1. Ouvrages, Normes et Publications Officielles :

- **National Institute of Standards and Technology (NIST).** (2020). Zero Trust Architecture (NIST Special Publication 800-207). Consulté sur : https://csrc.nist.gov/publications/detail/sp/800-207/final
- **Roesch, M.** (1999). Snort: Lightweight Intrusion Detection for Networks. Proceedings of LISA '99: 13th Systems Administration Conference. (Référence fondatrice pour les systèmes IDS/IPS).
- **Stallings, W.** (2016). Cryptography and Network Security: Principles and Practice (7ème éd.). Pearson.

2. Documentations Officielles et Techniques :

- **Deciso B.V.** (2026). OPNsense Official Documentation. Consulté sur : https://docs.opnsense.org/
- **MariaDB Foundation.** (2026). MariaDB Server Documentation. Consulté sur : https://mariadb.com/kb/en/documentation/
- **Open Information Security Foundation (OISF).** (2026). Suricata User Guide. Consulté sur : https://suricata.readthedocs.io/
- **OpenVPN Inc.** (2026). OpenVPN Community Documentation and Reference. Consulté sur : https://community.openvpn.net/
- **Squid Cache Organization.** (2026). Squid Proxy Configuration Manual. Consulté sur : http://www.squid-cache.org/Doc/
- **The Apache Software Foundation.** (2026). Apache Tomcat Documentation. Consulté sur : https://tomcat.apache.org/

3. Articles, Outils et Ressources Complémentaires (Webographie) :

- **Lubuntu Project.** (2026). Lubuntu Official Manual. Consulté sur : https://manual.lubuntu.me/
- **Nmap Project.** (2026). Nmap Network Scanning : The Official Nmap Project Guide to Network Discovery and Security Auditing. Consulté sur : https://nmap.org/book/
- **OffSec.** (2026). Kali Linux Documentation. Consulté sur : https://www.kali.org/docs/
- **Proofpoint (Emerging Threats).** (2026). Open Ruleset / Telemetry for IDS/IPS. Consulté sur : https://rules.emergingthreats.net/